

网络安全——

网络攻击——APT攻击与检测

北京邮电大学 网络空间安全学院

武 斌



主要内容

CONTENTS

1. APT简介
2. APT解析
3. APT检测



主要内容

CONTENTS

1. APT简介
2. APT解析
3. APT检测

APT:新兴安全威胁

The Washington Post

McAfee Calls Operation Aurora A "Watershed Moment In Cybersecurity" Offers Guidance

BBC

News

Sport

Weather

Capital

NEWS TECHNOLOGY

Home UK Africa Asia Europe Latin America Mid-East US & Canada Business Health



REUTERS

EDITION: U.S.

ARTICLE



LEARN MORE >

DISCOVER
BRILLIANT
INVESTMENT
INSIGHTS
WITH

Virus found in Middle E finance transaction

Thu Aug 9, 2012 8:59am EDT

* Gauss found in Lebanon, Is
Territories

* Kaspersky Lab describes Gauss as cyb

* Says it may also be able to cause phys

* Says may be from same 'factories' as S

By Jim Finkle

“火焰”病毒或引发网络战

人民日报
RENMIN RIBAO

近一段时间以来,一种新型电脑病毒“火焰”入侵了伊朗、黎巴嫩、叙利亚等中东国家

人民网 people
www.people.com.cn

韩国电视台和金融机构网络遭遇瘫痪

人民网首尔3月20日电 (记者马菲)韩国主要电视台和部分金融机构的网络从当地时间20日下午2点开始陆续遭遇瘫痪。

据韩国联合通讯社报道,韩国主要电视台KBS、MBC、YTN和新韩银行、农协银行等部分金融机构的网络当天遭遇瘫痪。韩国政府派遣联合应对小组进行调查后证实,网络瘫痪是由恶意代码所致。这些恶意代码破坏了计算机的主引导记录(MBR),导致网络瘫痪。

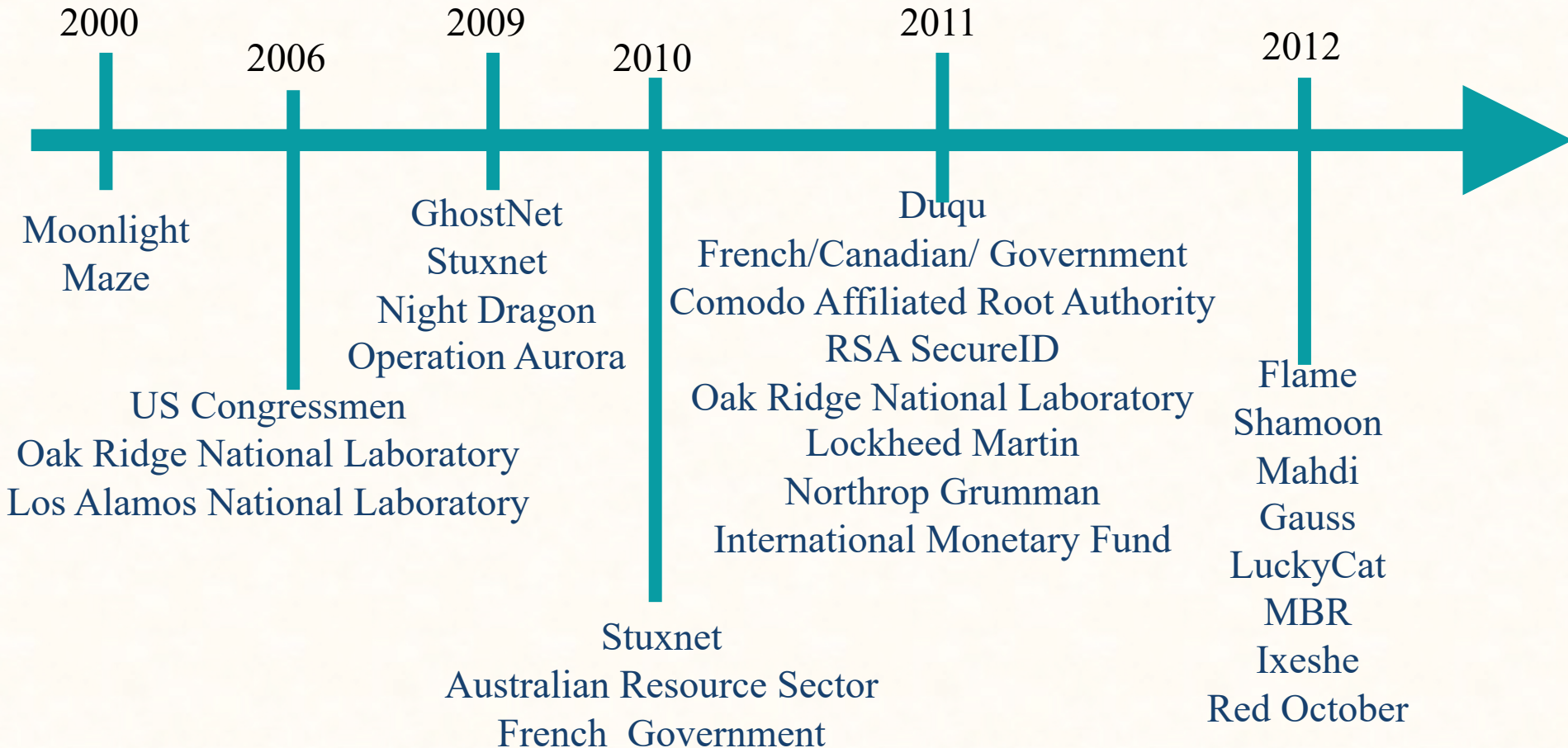
凤凰网 军事
mil.ifeng.com

凤凰网资讯 > 军事 > 环球军情 > 正文

“震网”：首个专门攻击物理基础设施的蠕虫病毒

一年前,美国和以色列曾警告说,伊朗只需一年就能拥有制造核武器的能力,但2011年2月伊朗突然宣布暂时卸载首座核电站的核燃料,从而西方国家认定伊朗的核计划因“技术问题”而被拖延。为什么会突然出现如此重大变化?原因是该核电站自2010年8月启用后,一种名为“震网”(Stuxnet)的蠕虫病毒,侵入了西门子公司为核电站设计的工业控制软件,导致1/5的离心机报废。

APT：新兴安全威胁



急速升温

APT：新兴安全威胁

APT危害极大：

Operation Aurora

- Google、Adobe等20多家公司遭受攻击
- IT巨头的源代码、用户资料泄露

Stuxnet攻击

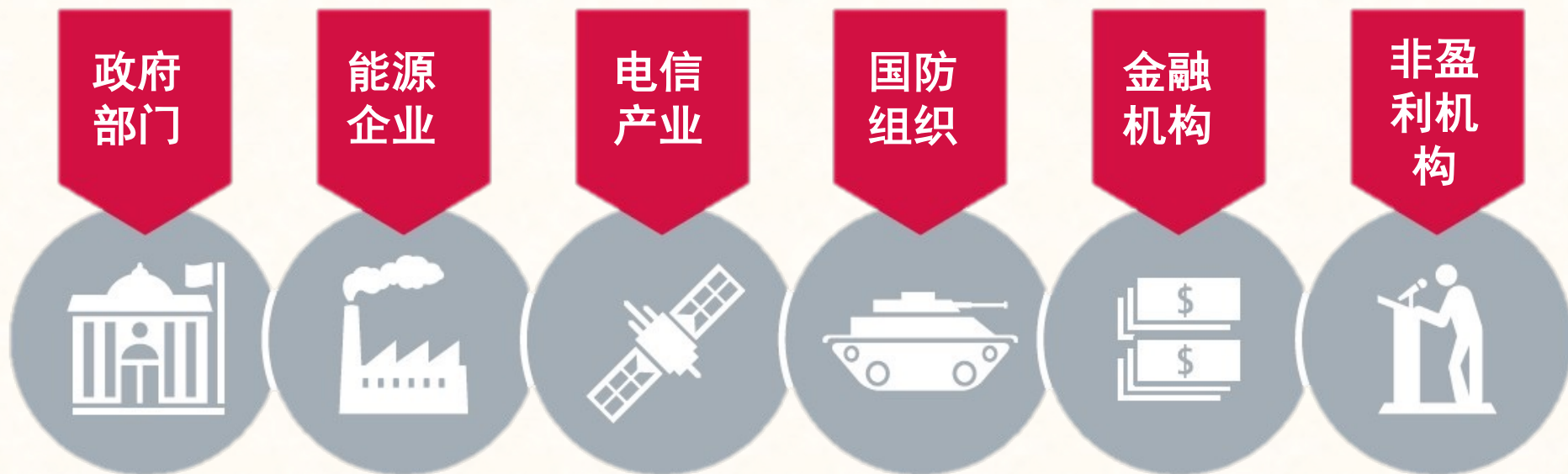
- 伊朗核设施瘫痪，核进程推迟近两年
- 震网病毒扩散传播后伊朗钢铁、电力、能源、化工等重要行业运行异常、商业资料失窃、停工停产

RSA SecureID 泄露

- 相关技术及客户资料被窃，导致大量使用SecureID作为认证凭据建立VPN的公司受到攻击
- 美国企业、政府等关键组织接连遭黑客攻击

APT：新兴安全威胁

作用于核心机构：



- 威胁国家安全稳定
- 对企业经济、信誉造成严重损害
- 影响行业、企业正常运营

APT起源

“APT”一词最初起源于2005-2006年间在美国空军工作的网络安全工程师们对于一些安全事件的描述，他们创造了这个词以使公众不在此类安全事件小题大做……

---Peter Cap 在 Bruce Blog 上的留言



Peter Cap

Threat Analyst at Microsoft

Redmond, Washington | Computer & Network Security

Previous Symantec Corporation, US Navy

Education Beloit College

Send Peter InMail

Bruce Schneier

Schneier on Security

A blog covering security and security technology.

[« Unlocking any iPad2 using a Smart Cover | Main | Commentary on Strong Passwords »](#)

November 9, 2011

Advanced Persistent Threat (APT)

It's taken me a few years, but I've come around to this buzzword. It highlights an important characteristic of a particular sort of Internet attacker.

A conventional hacker or criminal isn't interested in any particular target. He wants a thousand credit card numbers for fraud, or to break into an account and turn it into a zombie, or whatever. Security against this sort of attacker is relative; as long as you're more secure than almost everyone else, the attackers will go after other people, not you. An APT is different; it's an attacker who -- for whatever reason -- wants to attack you. Against this sort of attacker, the absolute level of your security is what's important. It doesn't matter how secure you are compared to your peers; all that matters is whether you're secure enough to keep him out.

APT attackers are more highly motivated. They're likely to be better skilled, better funded, and more patient. They're likely to try several different avenues of attack. And they're much more likely to succeed.

Peter Cap • November 9, 2011 3:33 PM

Well, Bruce, welcome to the debate, pull up a chair, make yourself comfortable.

Brief background--"APT" was originally coined in 2005 or 2006 by analysts working netsec issues for the Air Force. They created this term to discuss a *particular* threat with the press without invoking its classified covername. So, originally, it was actually meant to be a *name*--it could just as easily have been Biff or Steve or Maggie.

Later on, people who heard the term but did not necessarily do work in this area took it to stand for a *class* of threats. Then began the discussion on the nature of "advanced" when their typical M.O. involves spear-phishing and exploits from 2008 (ok, I'll allow that the methods of controlling their malware can get quite exotic) and how you define "persistent" (including one school that thought it meant "Patient and determined to get into your network" while another group insisted it meant "Once they establish a foothold, they will spread laterally and you will never get rid of them"--note that these are not mutually exclusive definitions).

Ultimately, as analysts, we use terms like "APT" as a shortcut--we take a whole body of data and slap a label on it--then we only work with that simple thought object rather than a giant data set. Only, if you do not already grok that data set, then the label really is devoid of value for you.

So, Maxim #1 for this post--if you are not actively engaged in analyzing and countering APT, then you have no business using the term, because it is a foreign word whose meaning you don't really understand. I mean this in the nicest possible way, not to shut anyone out, but just to make them aware that when you say "APT" it is a placeholder for a massive body of work that goes back over a decade and is truly globe-spanning. Not a space for dilettantes.

The corollary is that, as analysts, we use terms like this to *reduce ambiguity and complexity*. Therefore, if we fail at either then we are actually doing more harm than good.



Subscribe



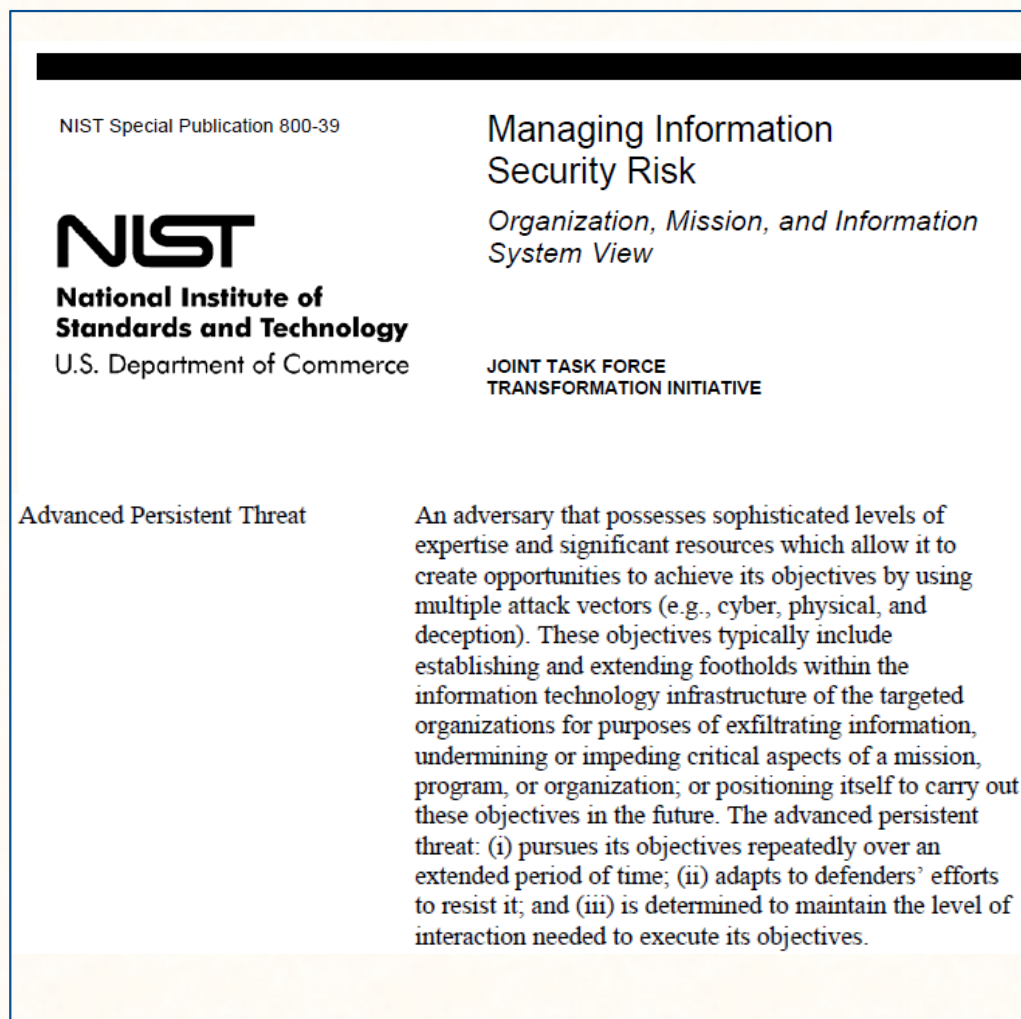
Subscribe via Kindle

APT定义

高级持续性威胁

——攻击者掌握**先进的专业知识**和**丰富有效的资源**，通过**多种攻击途径**(如网络、物理设施和欺诈手段等)，实现在特定组织的信息技术基础设施创建立足点，以窃取机密信息，破坏或阻碍任务、计划或组织的关键环节。此外，APT**会长时间重复地为实现其目标而努力**，能够**不断适应防御者**并产生抵抗能力，并为了达到目标**维持必需的交互和更新**。

美国国家标准与技术研究院
2011(NIST SP 800-39)





主要内容

CONTENTS

1. APT简介
2. APT解析
3. APT检测

APT攻击情况分析

APT攻击

高级的攻击技术背后是国家、军事的网络对抗

- Operation Aurora
Google、Adobe等20多家公司遭受攻击，源代码、用户资料泄露。
- Stuxnet攻击
伊朗核设施瘫痪。可能造成钢铁、电力、能源、化工等重要行业运行异常、商业资料失窃、停工停产。
- 火焰病毒
史上最复杂的病毒

APT实例(Aurora 极光)

概述

Motivation

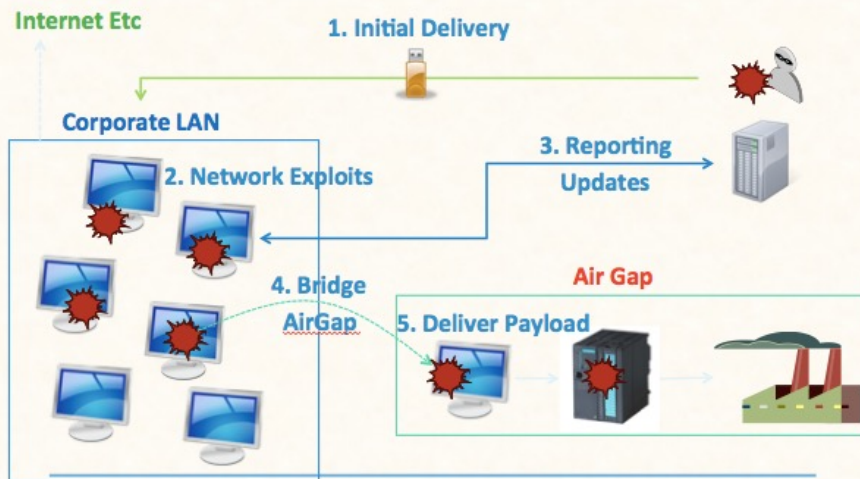
攻击意图

Target

攻击目标

APT实例:(Stunex 震网)

攻击过程



APT攻击情况分析

棱镜门

2013年，斯诺登事件暴露出美国针对全球各国的网络攻击、监听等计划



新华网 集成交互专题

美国“窃听门”丑闻

美国“情报机器”失控惹怒全球

首页 聚焦 解读 滚动 图片 视频 人物

美国全球监控地图曝光:中国5大城市成监控重点

这份地图包含了世界90个大小国家的监控点，而中国作为东亚的首要监听对象，香港、北京、上海、台北等城市榜上有名。

德国政界对美监听默克尔愤怒

德国媒体爆料称总理默克尔手机被美国国家安全局监听，引发政界严重关切。德国在野党政



视频 - 播客 - 微博 - 邮件 - 博客 - BBS - 我说两句 - 搜狗



评论 图片 调查

独家策划

A雇员在... 被牵涉其... 最关注的

搞情报的“临时工”

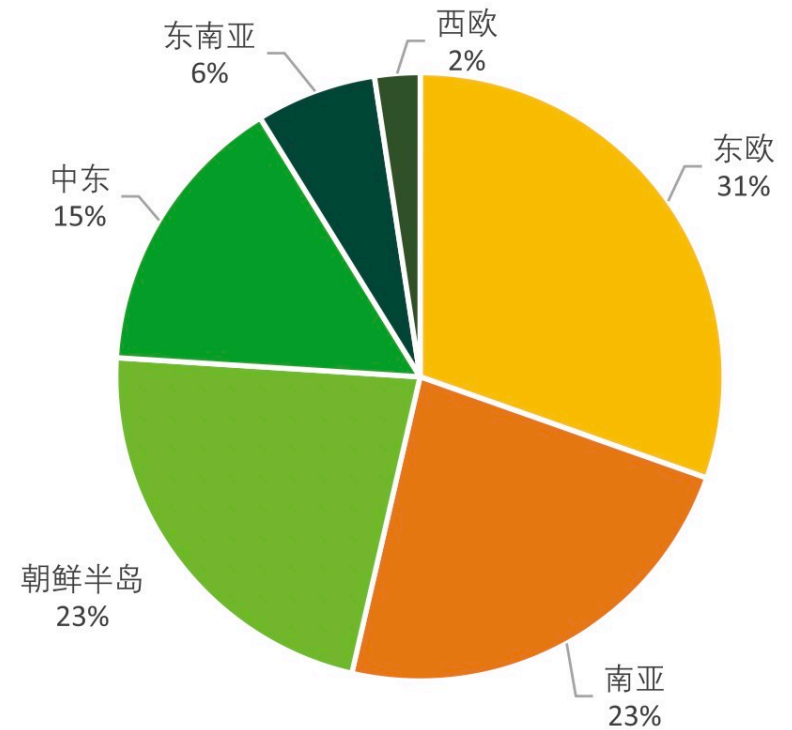
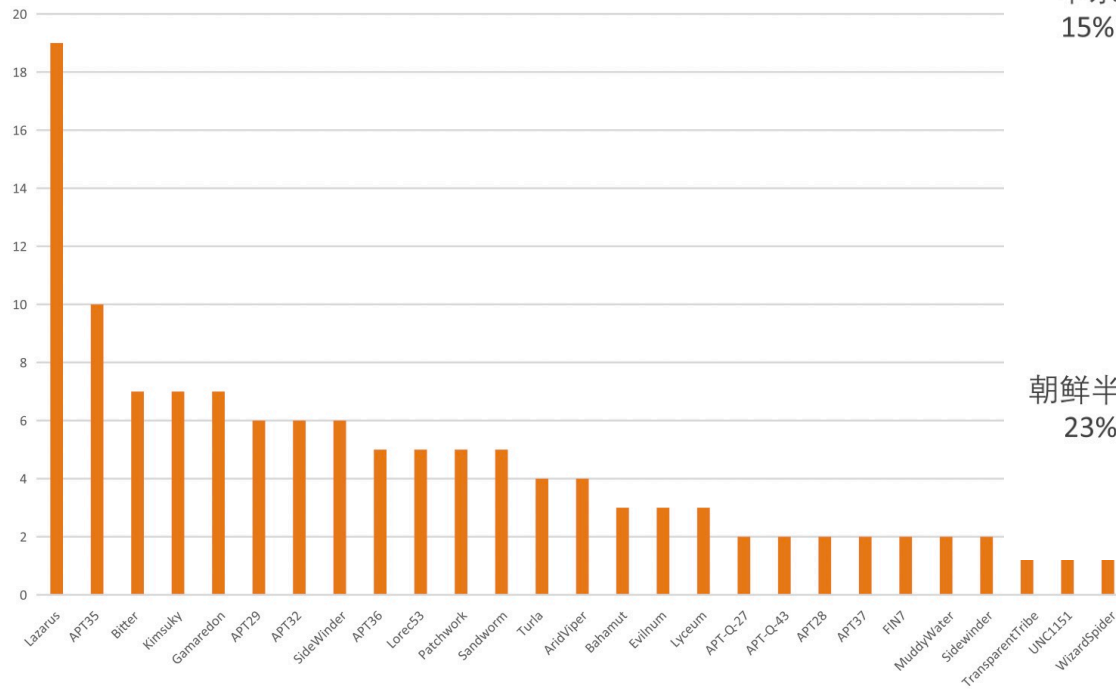


APT攻击情况分析

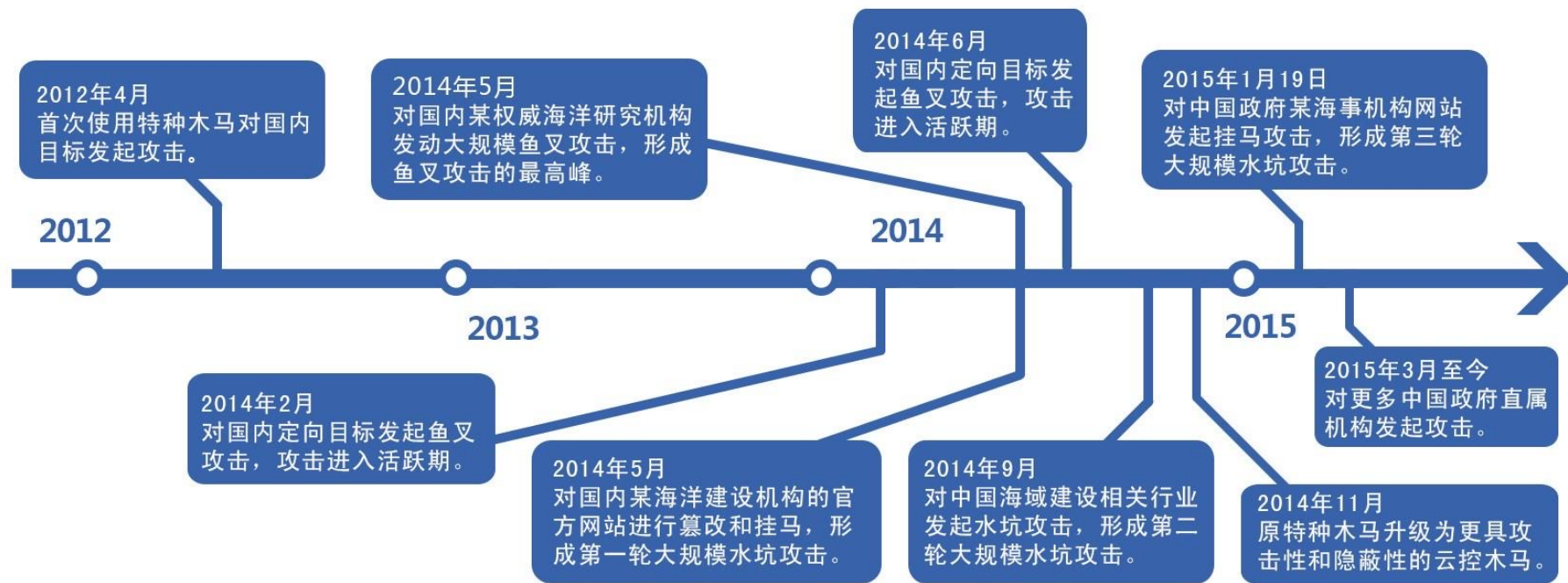
- 2023 年，**0day 漏洞**与 **Nday 漏洞**仍然是 APT 组织实现入侵行为的重要武器。
- APT 组织在2023年度已经开始广泛利用**常用软件漏洞、公网设备漏洞、驱动程序漏洞**等多种类型的漏洞代码，构建 APT 攻击武器并实现高效率的入侵攻击行为。
- 本年度被 APT 组织大规模利用的常用软件漏洞为针对 **WinRAR 软件的逻辑型 RCE 漏洞** CVE-2023-38831；最有代表性的公网设备漏洞为**针对 TeamCity 服务器的 RCE 漏洞** CVE-2023-42793；另有多多个驱动程序漏洞被 APT 组织用于 **BYOVD** 攻击。
- 2023年度捕获了多种复杂的新型 APT 木马，其中的代表为使用 rust 编写的 ZSkyRAT。

APT攻击情况分析

- APT组织



海莲花



drops.wooyun.org

APT攻击情况分析

● APT攻击技术手段

资源开发	初始访问	执行	持久控制	提权	绕过防御	凭证访问	发现	横向移动	收集	命令与控制	信息盗取	影响
收购基础设施	利用面向公众的应用程序	命令和脚本解释器	账户操作	漏洞利用提权	访问令牌操作	键盘记录	账户发现	远程服务	归档收集的数据	应用层协议	自动过滤	加密数据
获取攻击能力	外部远程服务	计划任务/工作	引导或登录自启动执行	劫持执行流程	混淆/解码文件或信息	操作系统凭证转信	文件和目录发现	通过可移动媒介介	本地系统数据	加密通道	通过其他网络介质进行盗取	网络拒绝服务
	网络钓鱼	系统服务	创建账户	进程注入	宿主机记录移除	窃取 Web 会话 Cookie	进程发现		电子邮件收集	工具传输	将数据转移到云账户	服务停止
	有效账户	用户执行	创建或修改系统进程	计划任务/工作	伪装		远程系统发现		键盘记录	协议隧道		系统关闭/重启
		Windows管理规范	外部远程服务	有效账户	修改注册表		软件发现		屏幕截图			
			劫持执行流程		混淆文件或信息		系统信息发现					
			计划任务/工作		进程注入		系统网络配置发现					
			服务器软件组件		破坏信任控制		系统网络连接发现					
					模板注入		系统所有者发现					
>20%	10%-20%	3%-10%			虚拟机/沙箱逃逸		虚拟机/沙箱发现					

Kill-Chain

- Kill-Chain 杀伤链
- 初始入侵 (Initial Compromise)
例如网站挂马或鱼叉式钓鱼攻击
- 建落脚点 (Establish Foothold)
安装木马后门
- 权限提升 (Escalation Privilege) 漏洞利用
- 内部侦查 (Internal Reconnaissance) 内部侦察目标系统信息
- 横向移动 (Move Laterally) 通过网络的横向移动渗透
- 保持存在 (Maintain Presence)
Command and Control (C&C)、
Remote Access Trojans (RATs)
- 完成任务 (Complete Mission)
泄露敏感信息

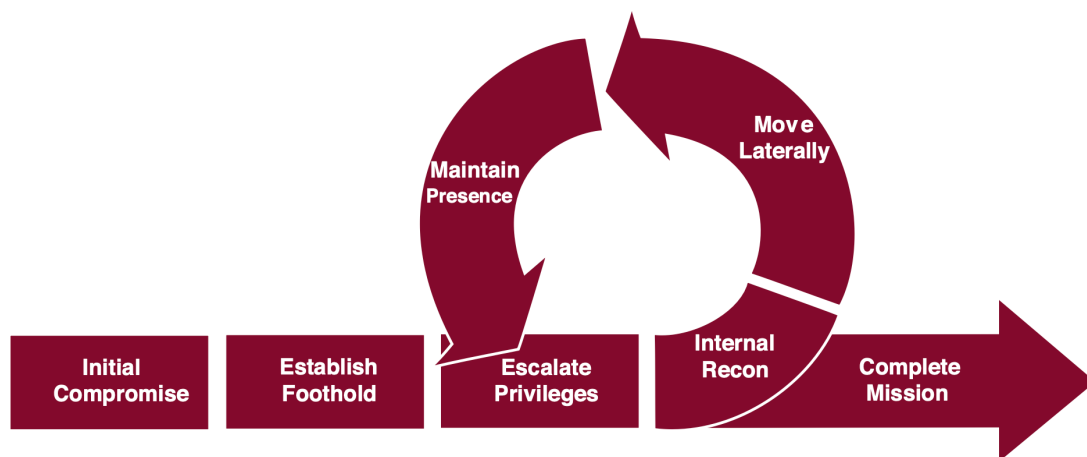


Fig. 1. APT Lifecycle.

APT攻击情况分析

APT 攻击趋势预测

- 供应链攻击频发，且正向上游组件、开源工具蔓延
- 开源黑客工具滥用，APT 组织归属特征愈发显得模糊
- 越来越多的APT 组织开始针对隔离网络进行定制化攻击

工具	组织
Cobalt Strike	Oceanlotus、FIN6、FIN7、APT29、Winnti 等
Metasploit	MuddyWater、TA505、Turla、DarkHydrus、APT33 等
Meterpreter	
PupyRAT	APT33、APT35、Rocket Kitten、COBALT ILLUSION 等
Mimikatz	Turla、OriRig、Fancy Bear、TA505、Black Energy 等
UACME	Patchwork、DarkHotel、Oceanlotus 等
QuasarRAT	Patchwork、CONFUCIUS、APT33、APT10 等
Powershell Empire	Sandworm、GADOLINIUM 等

APT实例(Aurora 极光)

概述

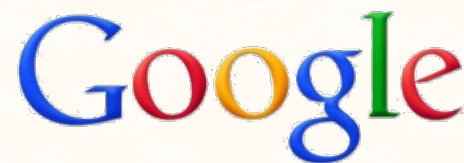
Motivation

攻击意图

- 窃取Google等公司的登录凭据、源代码及其他知识资产
- 窃取Gmail用户信息

Target

攻击目标



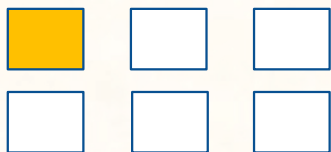
- Google为代表的高科技企业

极光是首个流行的对企业的APT攻击

APT实例(Aurora 极光)

1

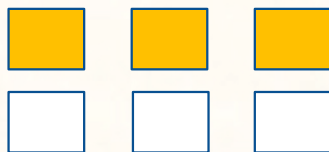
0day漏洞



CVE-2010-0249

3

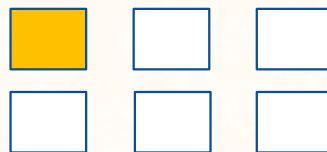
文件



%System%\[RANDOM].dll
%System%\acelpvc.dll
%System%\VedioDriver.dll

1

系统服务



RaS

[FOUR RANDOM CHARACTERS]

6

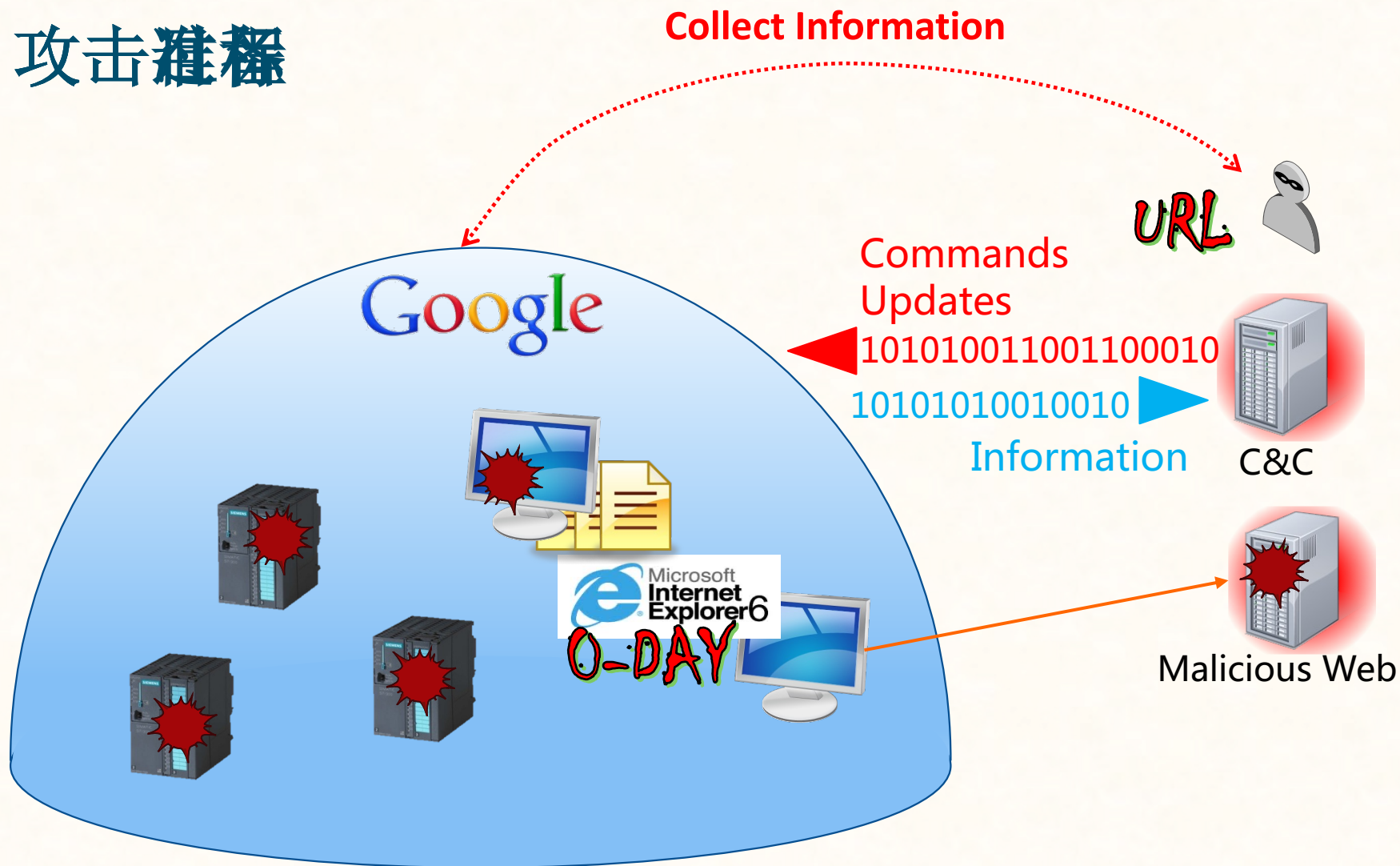
URL



yahooo.8866.org
sl1.homelinux.org
360.homeunix.com
li107-40.members.linode.com
ftp2.homeunix.com
update.ourhobby.com
blog1.servebeer.com

APT实例(Aurora 极光)

攻击流程



APT实例:(Stunex 震网)

概述

Motivation

攻击意图

- 改写工业控制系统代码，使工业系统按照攻击者的意图工作
- 向系统操作员隐藏其修改

Target

攻击目标



- 伊朗核电设施

Result

攻击后果

- 伊朗纳坦兹的核设施被破坏
- 伊朗布什尔核电站推迟启动

震网被称为第一个网络空间战武器

APT实例:(Stunex 震网)

先进性

4

0day漏洞



CVE-2008-4250
CVE-2010-2568
CVE-2010-2729
CVE-2010-2743

2

SCADA漏洞



硬编码漏洞
DLL加载策略缺陷

3

RootKit



2 Windows Rootkit
1 PLC Rootkit

2

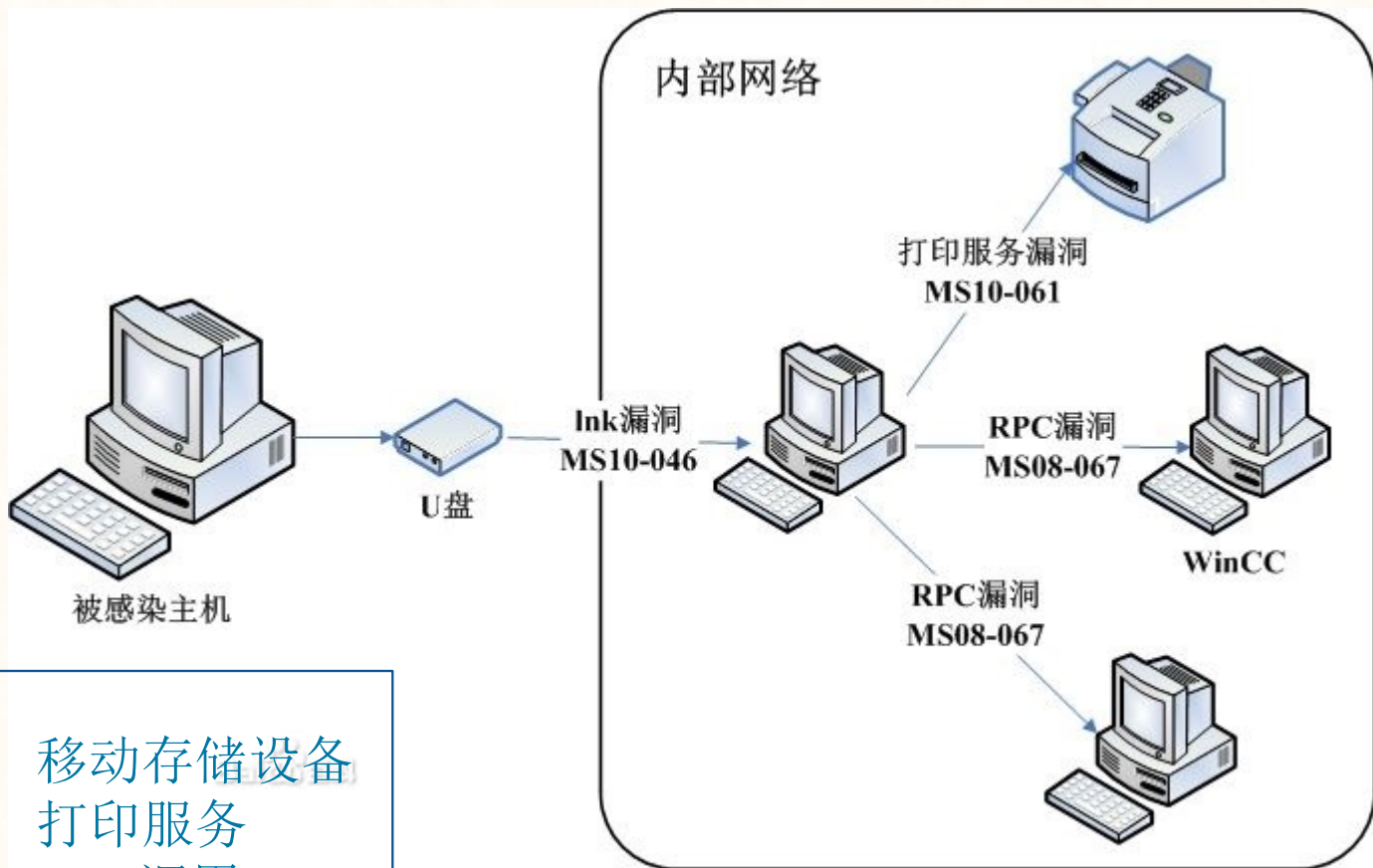
数字签名



Realtek Semiconductor
Corps
JMicon Technology Corps

APT实例:(Stunex 震网)

扩散



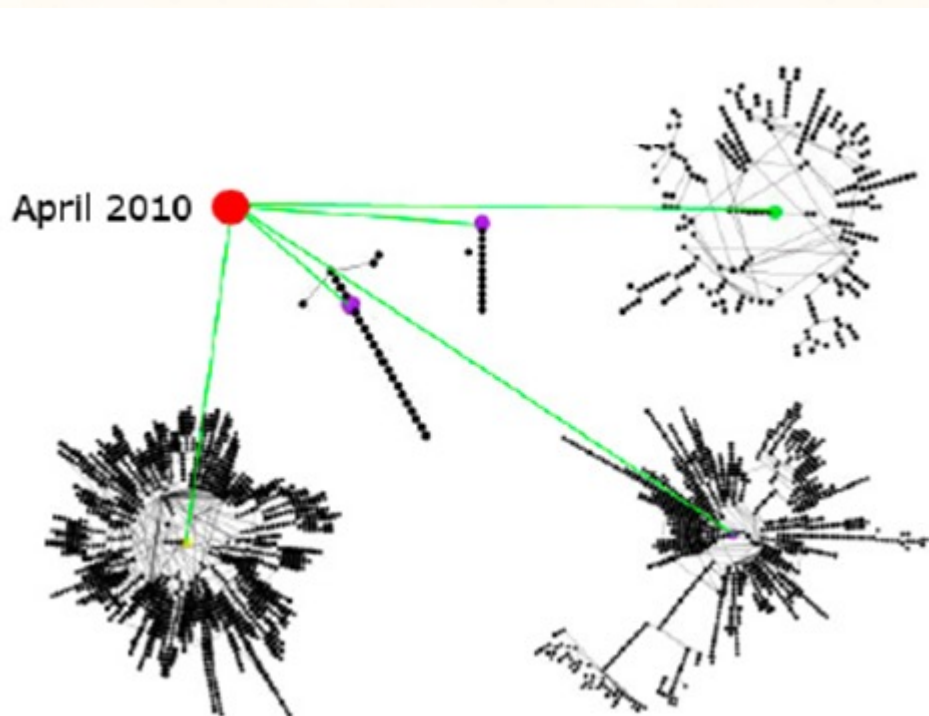
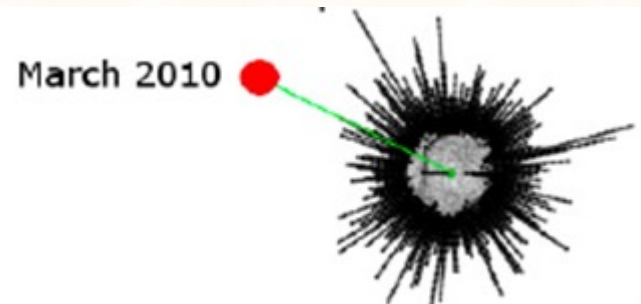
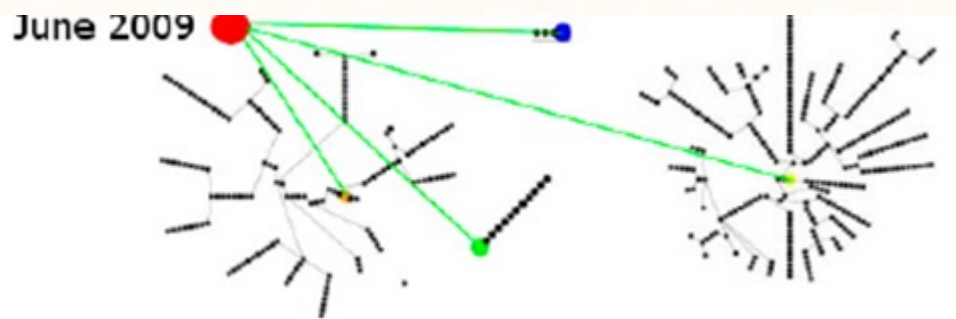
3



移动存储设备
打印服务
RPC调用

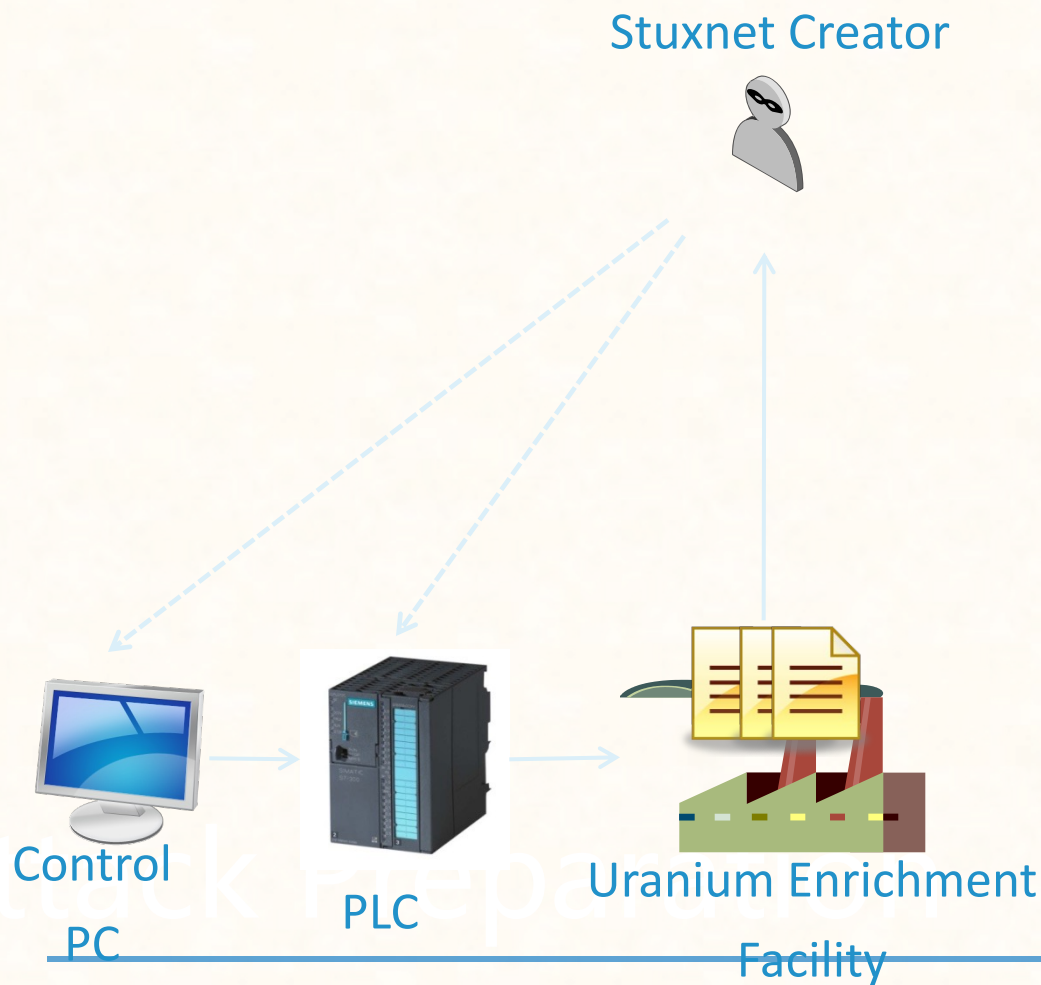
APT实例:(Stunex 震网)

扩散效果图



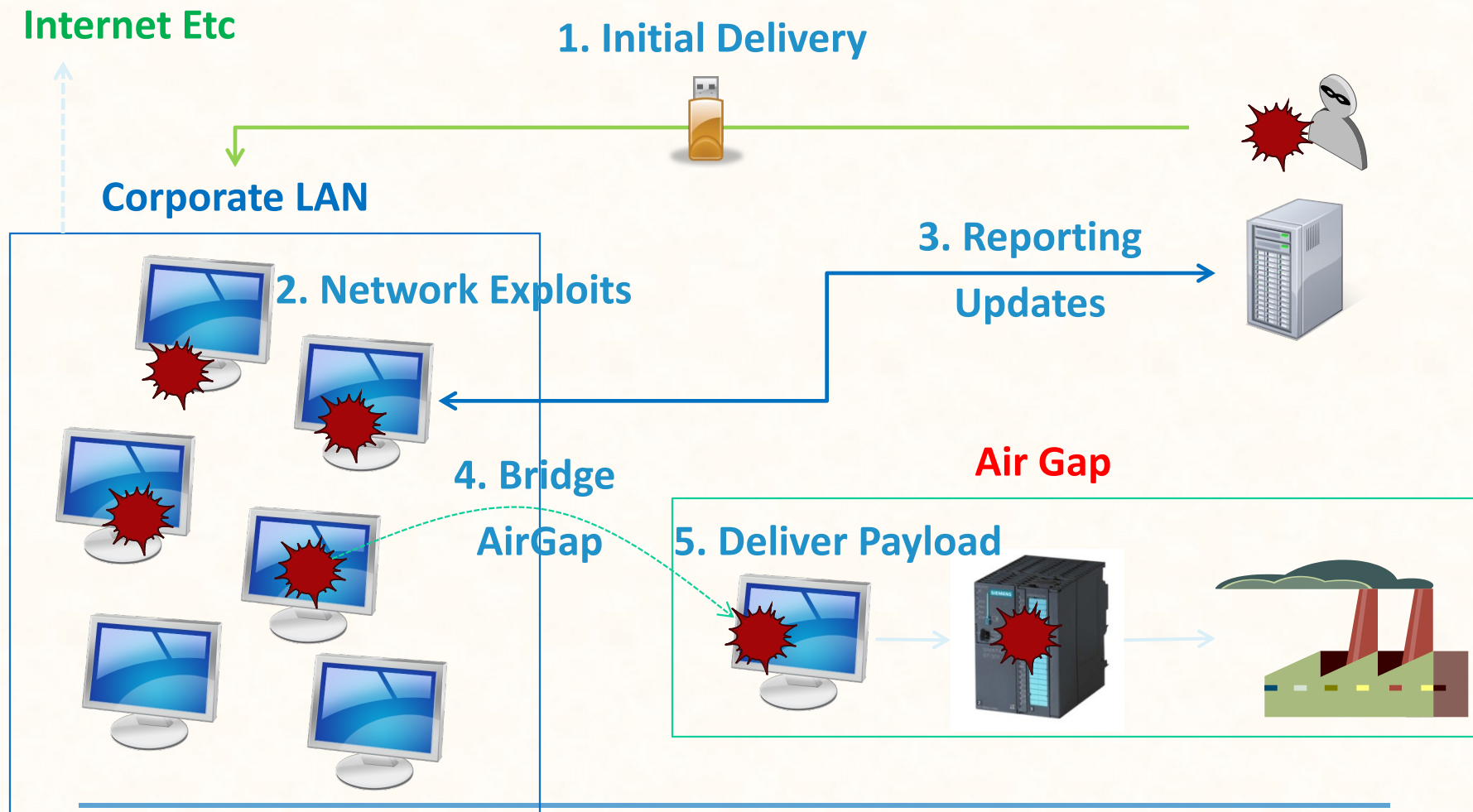
APT实例:(Stunex 震网)

攻击准备



APT实例:(Stunex 震网)

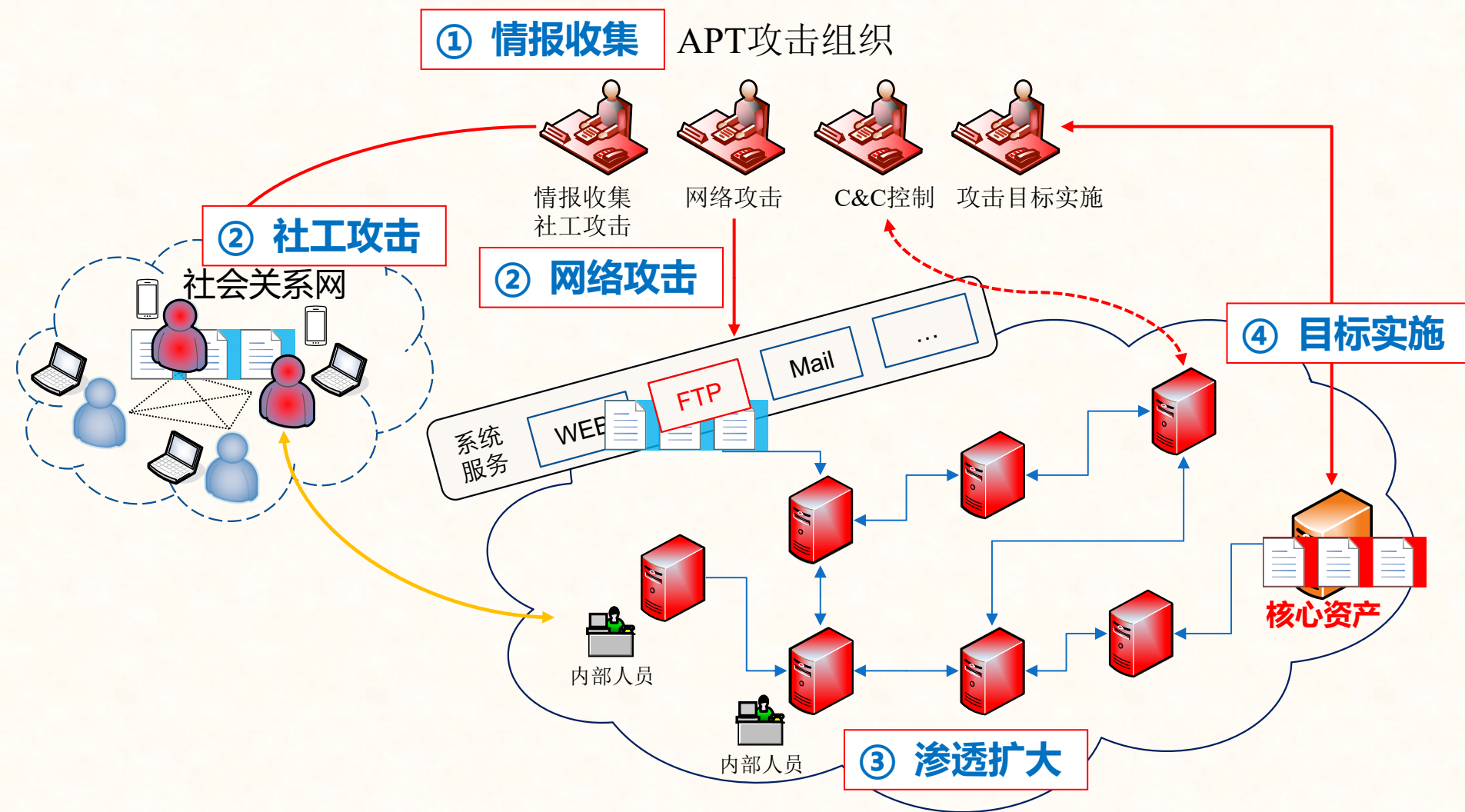
攻击过程



APT生命周期



APT攻击解析

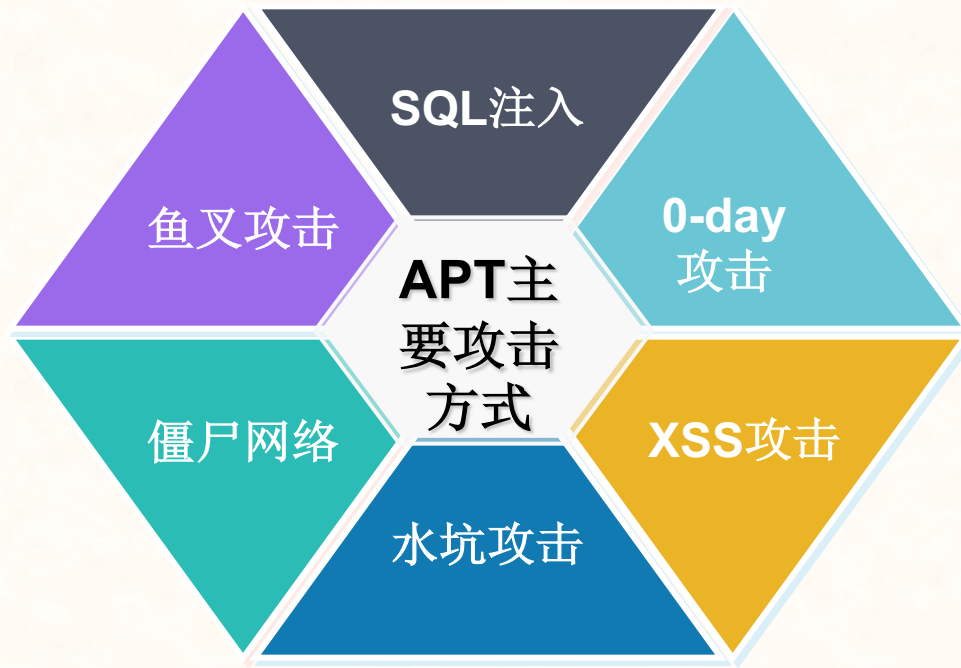


APT攻击的特点

APT 攻 击



APT攻击方式



APT攻击是多种攻击形式的混合利用。

水坑攻击

黑客通过分析被攻击者的网络活动规律，寻找被攻击者经常访问的网站的弱点，先攻下该网站并植入攻击代码，等待被攻击者来访时实施攻击。



鱼叉式网络钓鱼

- 鱼叉式网络钓鱼（Spear phishing）指一种源于亚洲与东欧[1]，只针对特定目标进行攻击的网络钓鱼攻击。
- 锁定之对象并非一般个人，而是特定公司、组织之成员，故受窃之资讯已非一般网络钓鱼所窃取之个人资料，而是其他高度敏感性资料，如智慧财产权及商业机密



典型APT攻击中的社工应用分析

	APT组织	属地	目标	目标领域	社工分析
钓鱼邮件	APT-C-36 (盲眼鹰)	南美洲	哥伦比亚	政企机构和大型公司	攻击组织第一次行动伪装DHL包裹投递（发件人：Parcel Delivery，主题：Shipment notification），邮件使用出货通知单来迷惑中招目标，第二次投递伪装成成政府邮件，发送伪装成pdf文件的恶意文档。该组织一直对政府部门保持高度的关注，自身也会伪装成相关部门进行邮件投递，同时仿冒政府网站进行钓鱼攻击。
	蔓灵花 (BITTER)	南亚	中国、巴基斯坦	重要机构	该组织的鱼叉邮件使用的攻击诱饵大都根据不同攻击对象进行定制，因而具有较强的迷惑性。并且通过鱼叉邮件投递的诱饵类型多样，在历次攻击中出现过一下类型的攻击诱饵。该组织会通过伪造身份向目标发送鱼叉邮件，投递恶意附件诱导受害者运行，或者先会选定部分容易攻破的邮箱进行针对性的攻击，获取部分种子受害者的邮箱账户及密码，然后攻击者会利用种子受害者邮箱账户，针对信任种子受害者的联系人定制诱饵邮件，再次发起二次攻击并扩大攻击范围。
	Hades		韩国	平昌冬奥会	攻击者伪装成韩国国家反恐中心（NCTC）的电子邮件地址发送鱼叉邮件，以及注册伪装韩国农业和林业部的恶意域名。
	APT-C-06 (DarkHotel)	韩国	中国、朝鲜、印度、日本		Darkhotel组织的攻击特色是通过入侵一些高档酒店的网络系统，掌控酒店WIFI，使用社会工程学手段，对登陆WIFI的目标发送伪造的提示，诱使其下载指定工具并升级，向目标主机植入恶意后门。由于攻击者控制了WIFI，且对目标的姓名、来去时间和房间号了如指掌，使得目标处于半监视环境中而不自知。近年来，该组织多次伪装正常软件包发动水坑攻击。此外，Darkhotel也使用钓鱼攻击。攻击者向企业高管和国家政要发送邮件，其主题经过精心设计，与行业政策态势或者政治热点问题密切相关，附件中则包含构造的恶意文件。这些文件多为快捷方式、自解压文件或携带Oday漏洞的文档，待目标打开运行即触发恶意行为。
	Lyceum	中东	能源和电信部门		攻击者将鱼叉式钓鱼邮件作为初始攻击入口，诱骗受害者点击下载docm文件或者伪装的SCR屏幕保护程序。攻击样本被下载执行后会释放一个诱饵文件来迷惑受害者。释放的诱饵PDF内容为“无人机击中伊朗帕尔钦军事基地”的新闻报道，原始报道发布时间为5月27日，可见攻击者希望通过近期热点事件迷惑受害者。
	白象	南亚	中国、巴基斯坦	科研、军事机构	所投递的攻击载荷名为“Covid19_Guidelines.docx”，文档标题“Guidelines for Government Employees and Organizations in the wake of COVID-19 epidemic”译为：政府机构应对新冠肺炎的指导方针。通过分析诱饵文件可知本次攻击事件中攻击目标为巴基斯坦相关行业从业人员。
					捕获到的两个攻击样本中的诱饵，分别是以巴基斯坦旁遮普政府劳动和人力资源部相关文档为诱饵和以巴基斯坦旁遮普政府监督与评估总局相关文档为诱饵。文档的页面设计与政府所用官方文档极其相似，使目标对钓鱼邮件的特点察觉不到；这些文档通常是RTF文档，由于是纯文本格式的文件，很容易让人放松警惕。
	蓝宝菇			政府、军工、科研、金融等重点单位和部门	主要采用鱼叉邮件携带二进制可执行文件这种攻击方法，攻击者仿冒官方邮件向受害者发送鱼叉邮件，附件多为一个WinRAR压缩包，其中包含伪装成Word文档的SCR文件。压缩包中的一个伪装成Word文件使用了RLO控制符，使得字符的显示顺序变成从右至左。从而来隐藏文件的真实扩展名。当受害者点击打开文档后，木马会在释放攻击代码的同时，释放一个真正的Word文档。鱼叉邮件仿冒博鳌亚洲论坛主办方向受害者发送了一封邀请函。邮件附件是一个163邮箱的云附件，为RAR压缩包文件。点开云附件，会跳转到对应的云端下载地址将附件下载到本地，下载得到包含恶意LNK文件的附件。

典型APT攻击中的社工应用分析

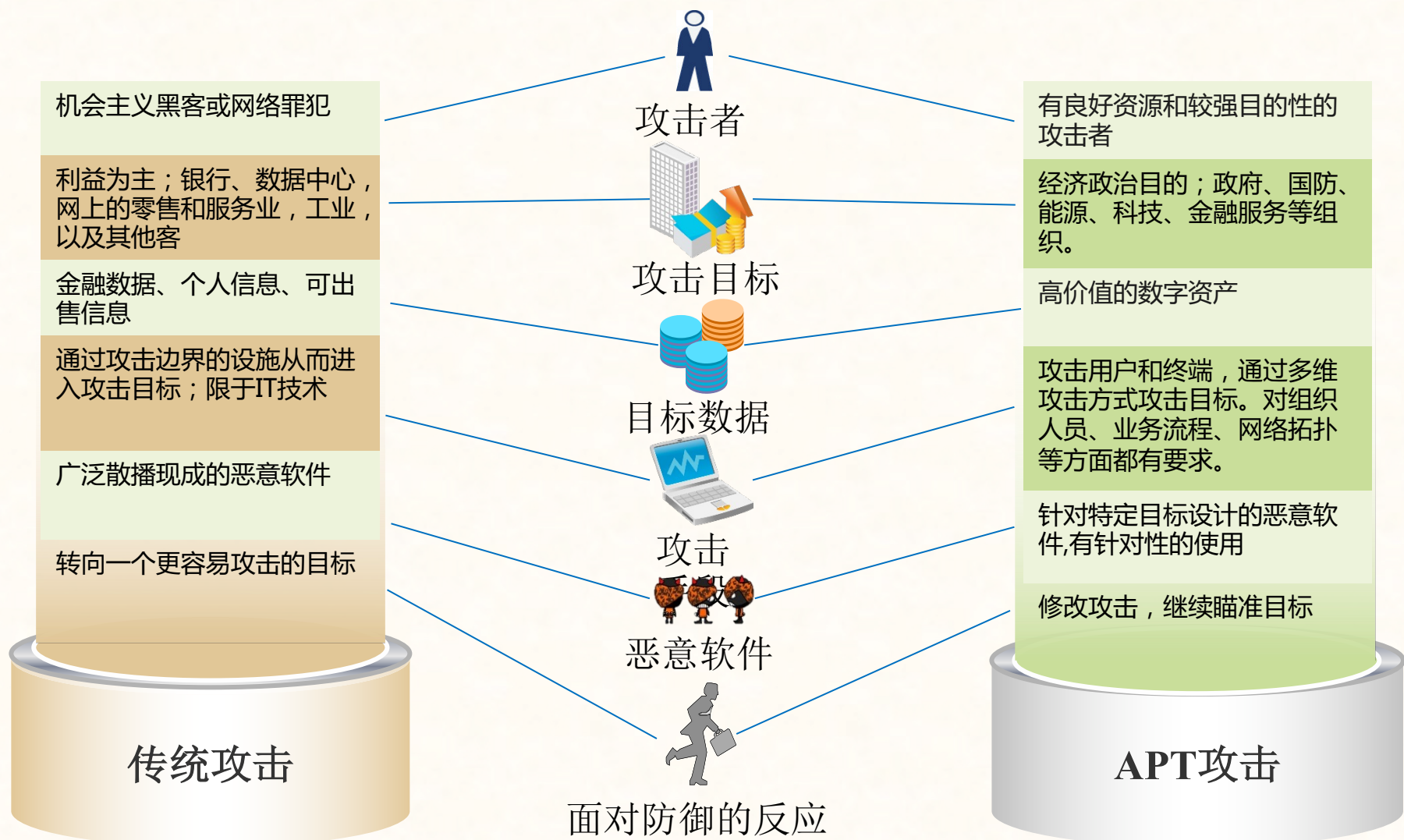
	APT组织	归属地	针对目标	目标领域	社工分析
钓鱼网站	APT-C-35（肚脑虫组织）	印度	巴基斯坦等	政府机构	一类会自己实现所伪装应用对象的功能，运行后展示出正常应用的形式来隐藏后台正在发生的间谍活动；另一类无正常应用功能，运行后提示诱导性欺骗消息，并隐藏图标删除快捷方式进行隐藏，实则后台进行间谍活动。文件图标伪装：伪装成针对性的克什米尔新闻、印度锡克教相关应用图标；伪装成通用性的VPN、谷歌服务相关应用；游戏
水坑攻击	APT-C-33（ArmaRat）	中东地区	伊朗	政府	伪装成社交、系统、色情视频及Adobe flash player等应用；伪装成伊朗特色节日“诺鲁孜节”的应用
	APT-C-23（双尾蝎）	中东地区	巴勒斯坦占84.8%，以色列占8.1%、驻外大使馆	教育机构、军事机构、政府、it	1. 通过winrar的自解压功能将相关样本文件和诱饵文件打包为exe文件；exe母体文件主要通过图标进行伪装，涉及的图标包括安装补丁、视频、文档等，文件名一般是针对目标进行精心构造的文件名。2. 诱导文档：高考成绩。3. 诱导app，“Tawjihi 2016”
	APT-C-15（人面狮）	中东地区	埃及、以色列	政府	文档诱导；自身伪装：伪装成文档、图片或安装程序
	APT-C-27（黄金鼠组织）	中东地区	叙利亚	军事、政府	文档诱导：文档指出用户所用版本为旧版本，提醒用户及时更新；文件图标伪装；特殊文件格式（scr后缀）和诱导文件名；伪装恶意更新程序，弹出正常的软件更新页面以迷惑用户
	APT-C-37组织（拍拍熊）	中东地区	ISIS	军事、政府	1. 对文件图标进行伪装；2. 把RAT插入到正常的APP中使得运行后展示正常界面，但当接收到指定的广播时，便在后台进行间谍活动。
	APT-C-00（海莲花）	越南	中国、越南	政府、科研	邮件内容和附件的命名与海洋相关企业事业单位建设、海洋资源、中国的党政机关、科研院所等密切相关。使用长文件名，隐藏exe后缀。
	APT-C-07（美人鱼）	中东地区	丹麦	政府	自身伪装：对二进制可执行EXE文件，主要从文件名、文件扩展名和文件图标等方面进行伪装。通过winrar的自解压功能将相关样本文件和诱饵文档打包为EXE文件，其中诱饵文档涉及的方面较多，会涉及安装补丁、开发环境、视频、图片、文档等，但就EXE文件母体很少将文件图标替换为文档或图片图标。

APT社工特征集

- 汇总APT社工在攻击目标、攻击目的、攻击风格、攻击手段等方面的特征
- 依据特征分析和提取，可以较准确筛选出可能是APT环节的社工攻击

分类			特征
攻击目标	目标单位类型		是否为政府、军事、科研等重要领域机构
	目标职级		职级等级高低
	目标常用网站		是否为新闻网站、政府官网等
	目标常用邮箱		是否为常用邮箱所在来源
攻击目的（结果）	目标损失		数据损失、组织破坏 钱财损失
攻击风格	场景构建		是否为工作场景
	周期性		相似来源攻击发生时间和次数
	群体特征		多个收件人是否具有群体特征（同一机构或高度领域相似性）
攻击手段	钓鱼网站	URL	域名注册商
			域名注册国家
		网页内容	网页是否有表单元素
			网站中的表单内容
	钓鱼邮件	文件	网站是否含有恶意链接
			网页中的语义特征
		附件	文件名称
			邮件附件类型
		链接	邮件附件名称
			邮件文本是否含有恶意链接
	水坑	联系人	收件人身份
			发件人
		JS脚本	复杂程度
			网站是否含有恶意链接

APT vs. 传统攻击



APT vs. 传统攻击

攻击形式	攻击定向性	传播性	可控性	窃密性	危害
APT攻击	高度定向	定向传播	完全可控	主要目的	基础设施、敏感信息等全面威胁
僵尸网络	定向	具备	可控	有	被控攻击
蠕虫	不定向	主动传播	不可控	无	影响网络、系统
木马	定向	较弱	可控	有	信息窃取为主
病毒	不定向	用户干预	不可控	无	破坏系统

安全措施亟待提升

APT攻击通常定制攻击，能够避开传统安全工具的检测

A

传统安全工具无法将攻击事件关联起来，无法在长时间维度上检测攻击

P

APT攻击包括物理攻击、社工攻击等非网络攻击手段。能够对目标造成全面威胁

T

APT攻击是目标明确、定制化、智能的攻击。传统安全工具无法检测出攻击的总目标

T

Advanced
Persistent
Threat
Target



主要内容

CONTENTS

1. APT简介
2. APT解析
3. APT检测

APT攻击检测难点

- 攻击方式复杂
- 攻击手段多样
- 攻击来源不明

A特征

- 攻击持续时间长
- 攻击过程片段化

P特征

- 攻击数据量大
- 攻击产生告警多
- 关联分析难度大

大数据

APT攻击检测亟待解决的问题

微观角度

- 0day攻击
- 未知攻击

难以发现

宏观角度

- 攻击过程
- 攻击目的

片段化
难以还原

网外因素

- 社工方法
- 非电子化因素

难以发现
多被忽略

APT攻击检测——要点

- 攻击过程不可能完全隐身
 - 攻击过程还原
 - 攻击片段组合
 - 攻击数据挖掘
- 未知攻击可实现部分检测
 - 0day漏洞
 - 终端安全
 - 通信分析
- 特定目标重点防护
 - 安全技术
 - 安全管理

APT攻击检测——关联分析

- 通过数据之间的关系进行关联，将具有共同特征的数据统一处理
 - 地址
 - 邮件账号
 - 用户名
 - 即时通信、社交网络等身份
 - 关系
 - 优点：直观、容易处理
 - 缺点：很多数据不具有共同特征
 - IOC(Indicators of Compromise)，威胁情报
 - 由可被边界安全设备和主机安全防护软件所使用的数据所构成，典型的入侵指示器有文件HASH、IP、域名、程序运行路径、注册表项等。
-

APT检测方案

□基于0day漏洞和恶意软件检测的APT检测方案

■主要技术：沙箱隔离，终端执行控制



□基于大数据分析的全流量APT检测方案

■主要技术：大数据存储，应用和文件还原，数据关联性分析



AT&T SECURITY RESEARCH CENTER

APT检测方案

❑ 基于0day漏洞和恶意软件检测

● 检测原理

● 解决方案

❑ 基于大数据分析

● 检测原理

● 解决方案

漏洞利用的软肋

操纵内存
部署代码

利用漏洞
跳转执行流

Shell Code
代码执行

没有能力影响执行逻辑

需要利用系统当中的特定指令、特定内存布局、需要内存属性变更

需要系统调用

APT检测方案

❑ 基于0day漏洞和恶意软件检测

● 检测原理

● 解决方案

❑ 基于大数据分析

● 检测原理

● 解决方案

0day漏洞检测手段

操纵内存
部署代码

利用漏洞
跳转执行流

Shell Code
代码执行

内存布局侦测
内存块源头追踪
关键指令代码监控
预先内存占坑

系统调用入口埋点
系统调用环境检测
调用来源内存属性检测
调用链条回溯

APT检测方案

❑ 基于0day漏洞和恶意软件检测

● 检测原理

● 解决方案

❑ 基于大数据分析

● 检测原理

● 解决方案

未知恶意代码软肋

必然落在一个**终端**上

必然要在此终端上**运行**

必然需要接触**敏感数据**

必然有**网络行为**

未知恶意代码检测

主动防御+隔离沙箱

--- 监控和审计程序的敏感行为，包括网络行为

--- 模拟执行环境，实行隔离

终端执行代码控制

--- 只运行经过检测的可信程序（白名单）

--- 将攻击者逼回到漏洞利用

APT检测方案

❑ 基于0day漏洞和恶意软件检测

● 检测原理

● 解决方案

❑ 基于大数据分析

● 检测原理

● 解决方案



启发式追踪

- 利用启发式方法检测追踪恶意软件的外壳代码片段
- 片段拼接，识别攻击的真正意图



多维沙箱

- 领先的沙箱技术
- 多维虚拟执行



私有云安全系统

- 应用、文件可信管控
- 基于主机文件保护的私有云安全防护体系

APT检测方案

❑ 基于0day漏洞和恶意软件检测

● 检测原理

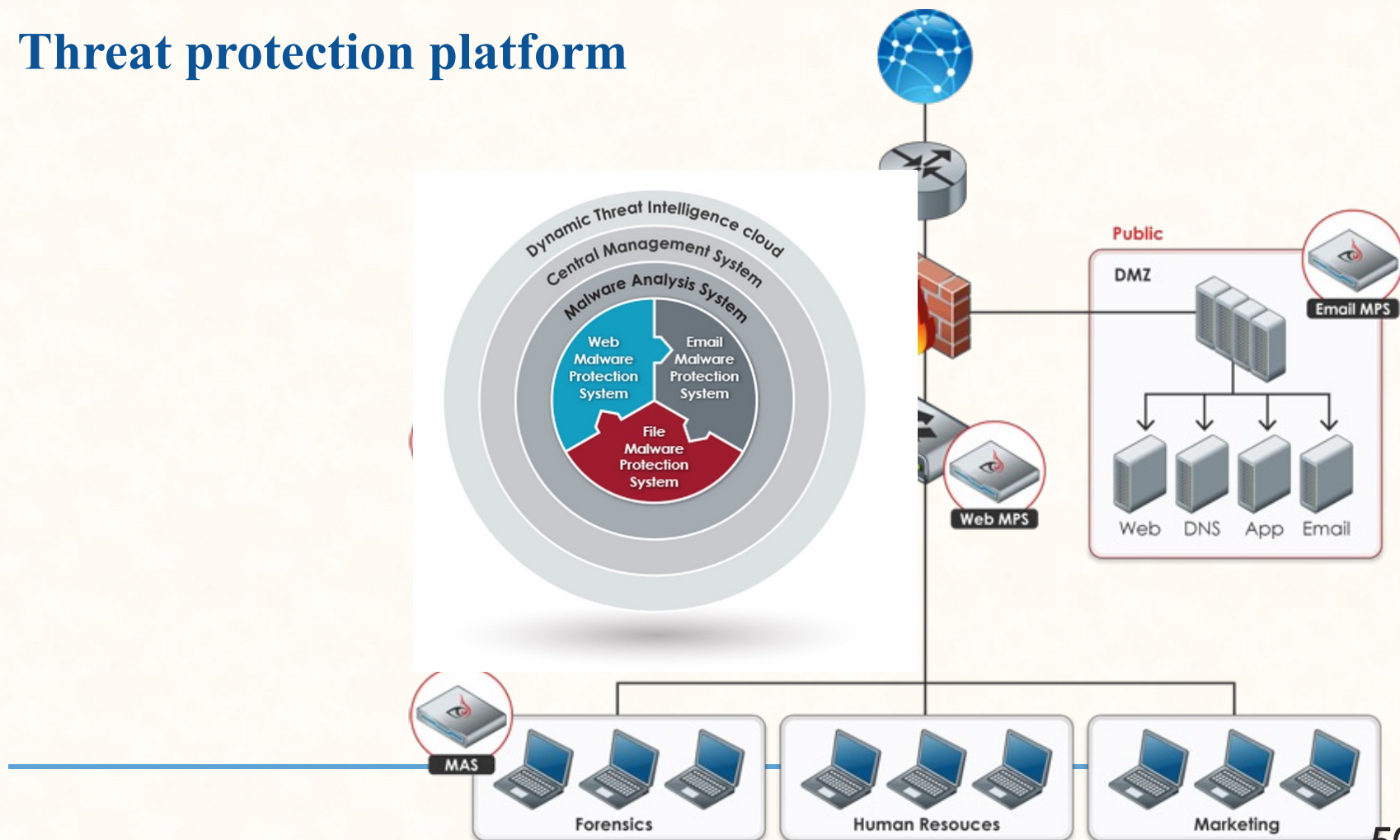
● 解决方案

❑ 基于大数据分析

● 检测原理

● 解决方案

Threat protection platform

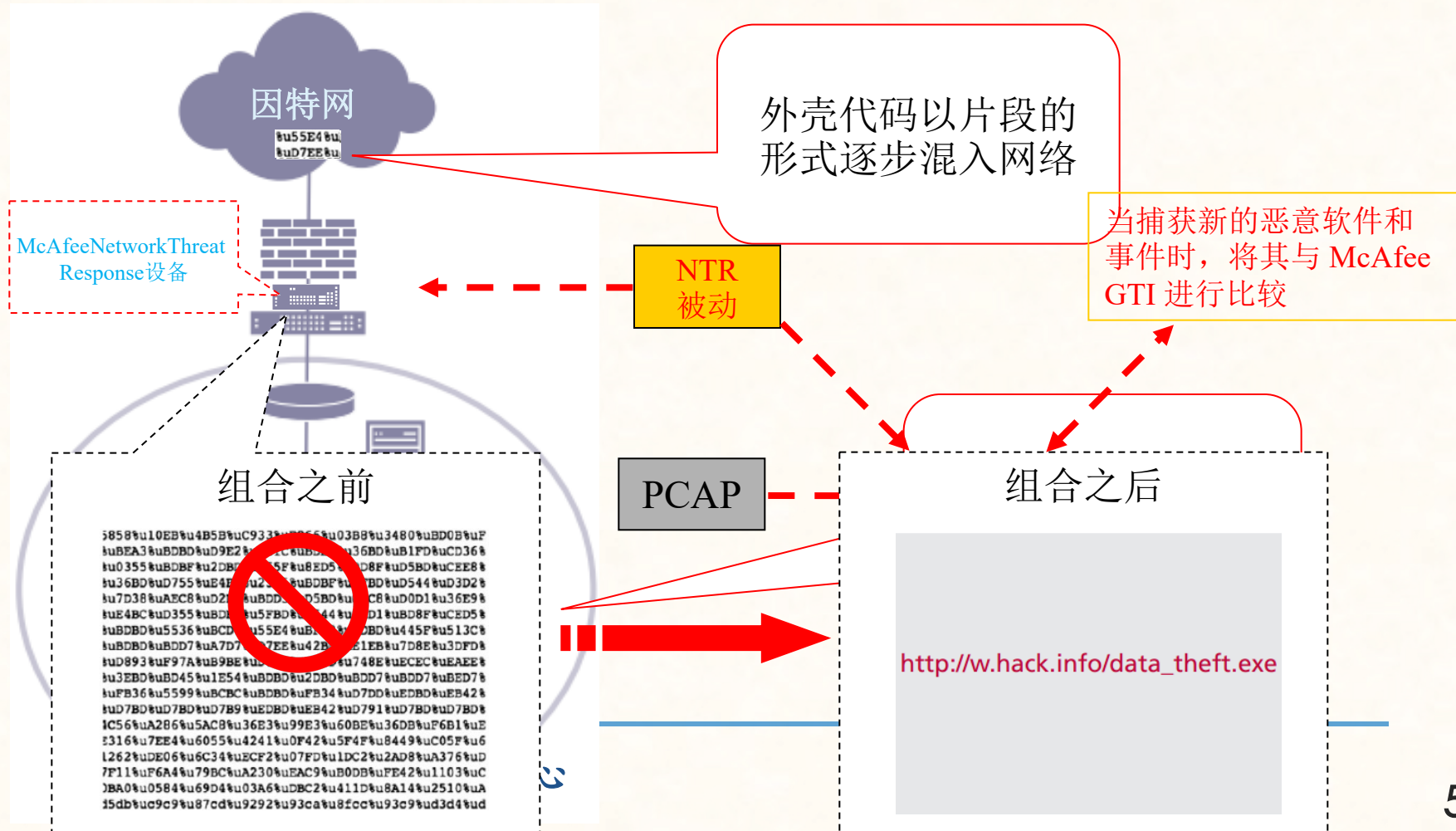


APT检测方案

❑ 基于0day漏洞和恶意软件检测
● 检测原理 ● 解决方案

❑ 基于大数据分析
● 检测原理 ● 解决方案

Network Threat Response



APT检测方案



❑ 基于0day漏洞和恶意软件检测

● 检测原理

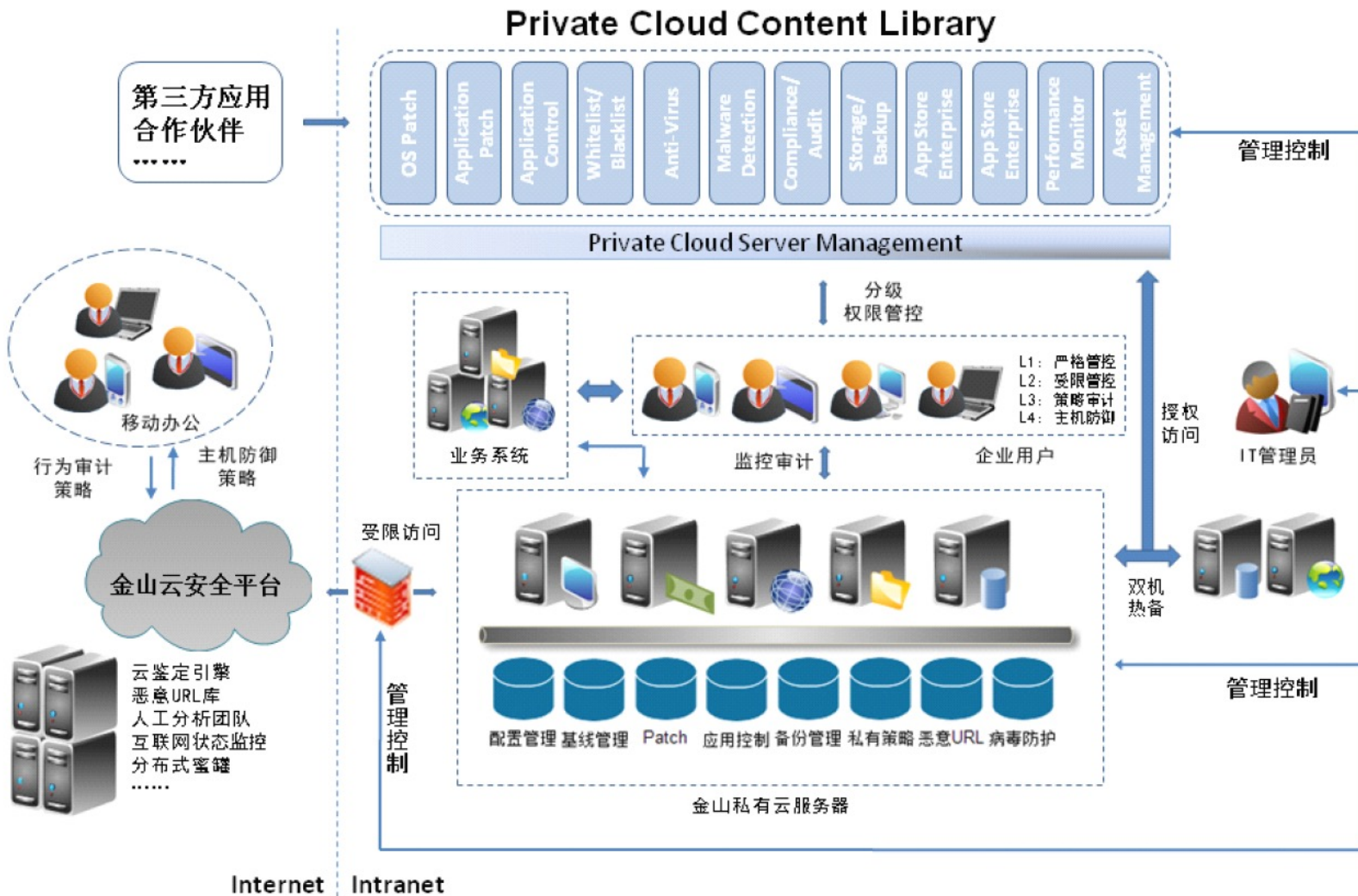
● 解决方案

❑ 基于大数据分析

● 检测原理

● 解决方案

基于主机的白名单策略



APT检测方案

□ 基于0day漏洞和恶意软件检测
检测原理 解决方案

□ 基于大数据分析
检测原理 解决方案

APT特征

攻击特征难以提取
单点隐蔽性强
攻击渠道多样化
持续和隐蔽时间长

大数据分析

数据覆盖

-----时间：APT攻击整个过程；
-----空间：终端、网络、人员等的全记录；

全流量分析

-----数据降维，知识，
关联性分析

APT检测方案

❑ 基于0day漏洞和恶意软件检测

- 检测原理
- 解决方案

❑ 基于大数据分析

- 检测原理
- 解决方案



SECURITY

大数据检测策略

- 搜集终端、服务器上的日志信息
- 搜集网络设备上的原始流量
- 数据处理、挖掘



AT&T SECURITY RESEARCH CENTER

基于上下文的大数据检测

- 时间维度上涵盖APT每一步骤的所有事件
- 空间维度上涵盖物理层、用户层和网络层三层所有安全事件
- 通过IP和用户组成安全事件的上下文

APT检测方案

RSA

❑ 基于0day漏洞和恶意软件检测

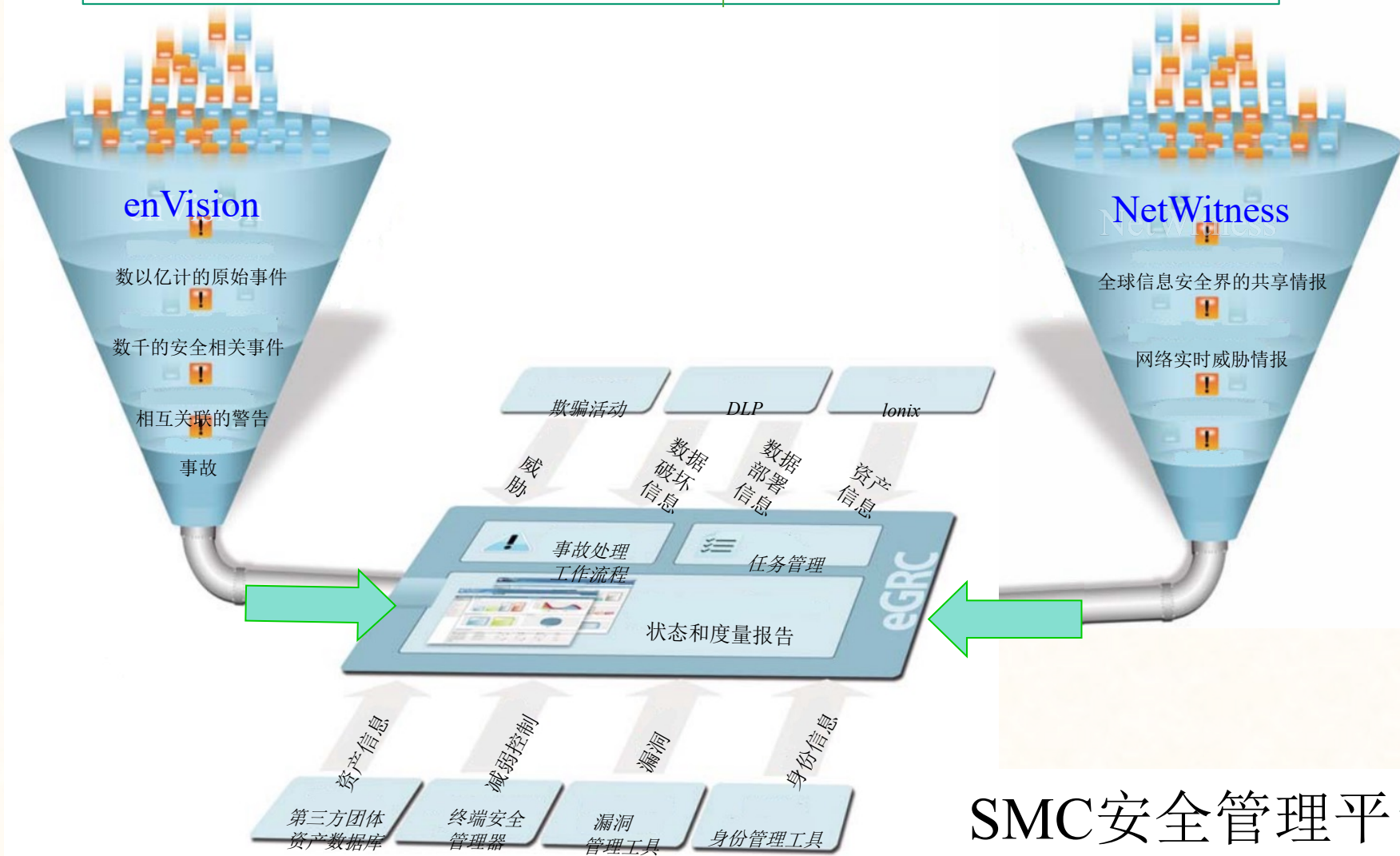
● 检测原理

● 解决方案

❑ 基于大数据分析

● 检测原理

● 解决方案



APT检测方案

RSA

❑ 基于0day漏洞和恶意软件检测

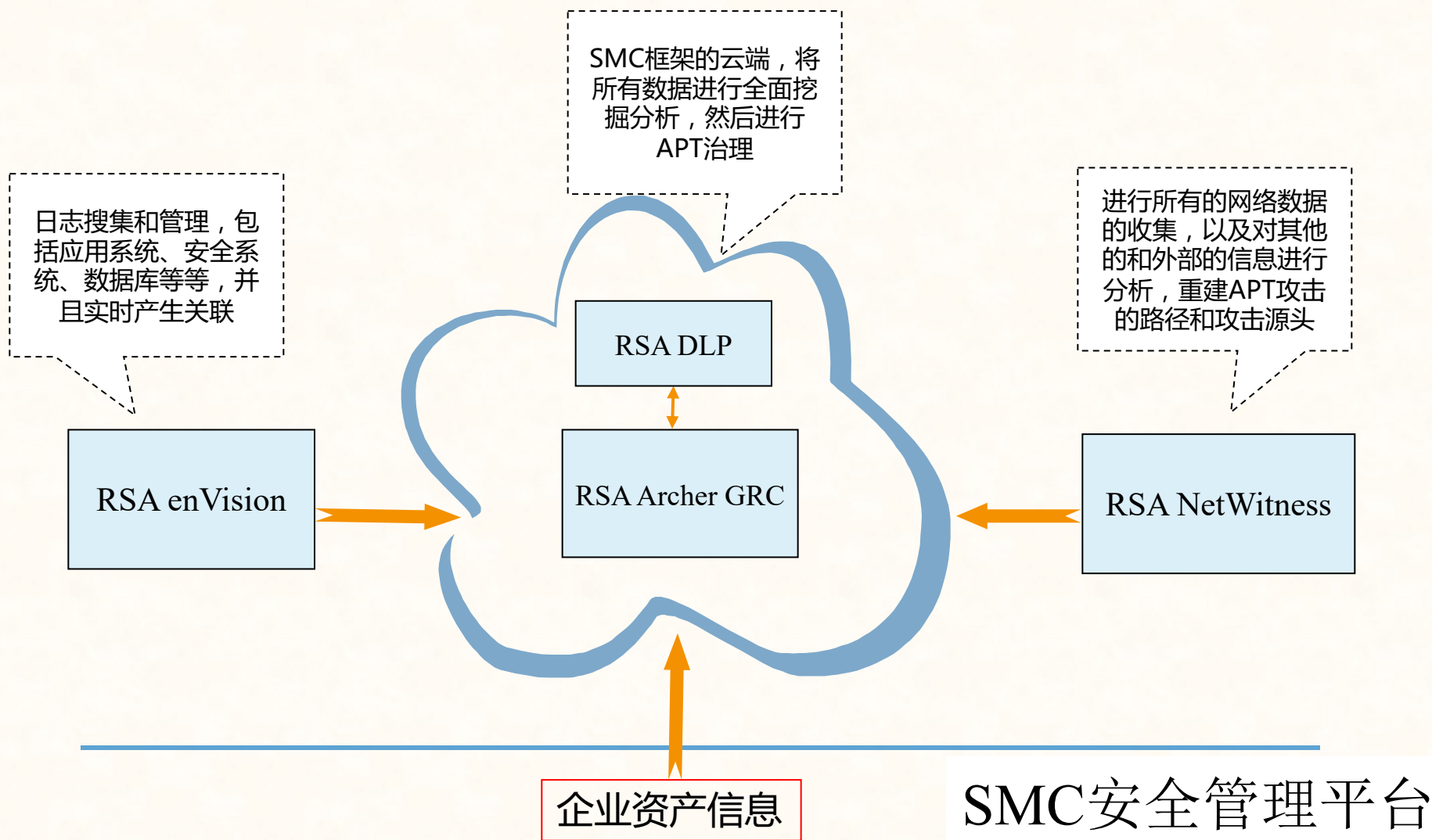
● 检测原理

● 解决方案

❑ 基于大数据分析

● 检测原理

● 解决方案



APT检测方案



AT&T SECURITY RESEARCH CENTER

❑ 基于0day漏洞和恶意软件检测

● 检测原理

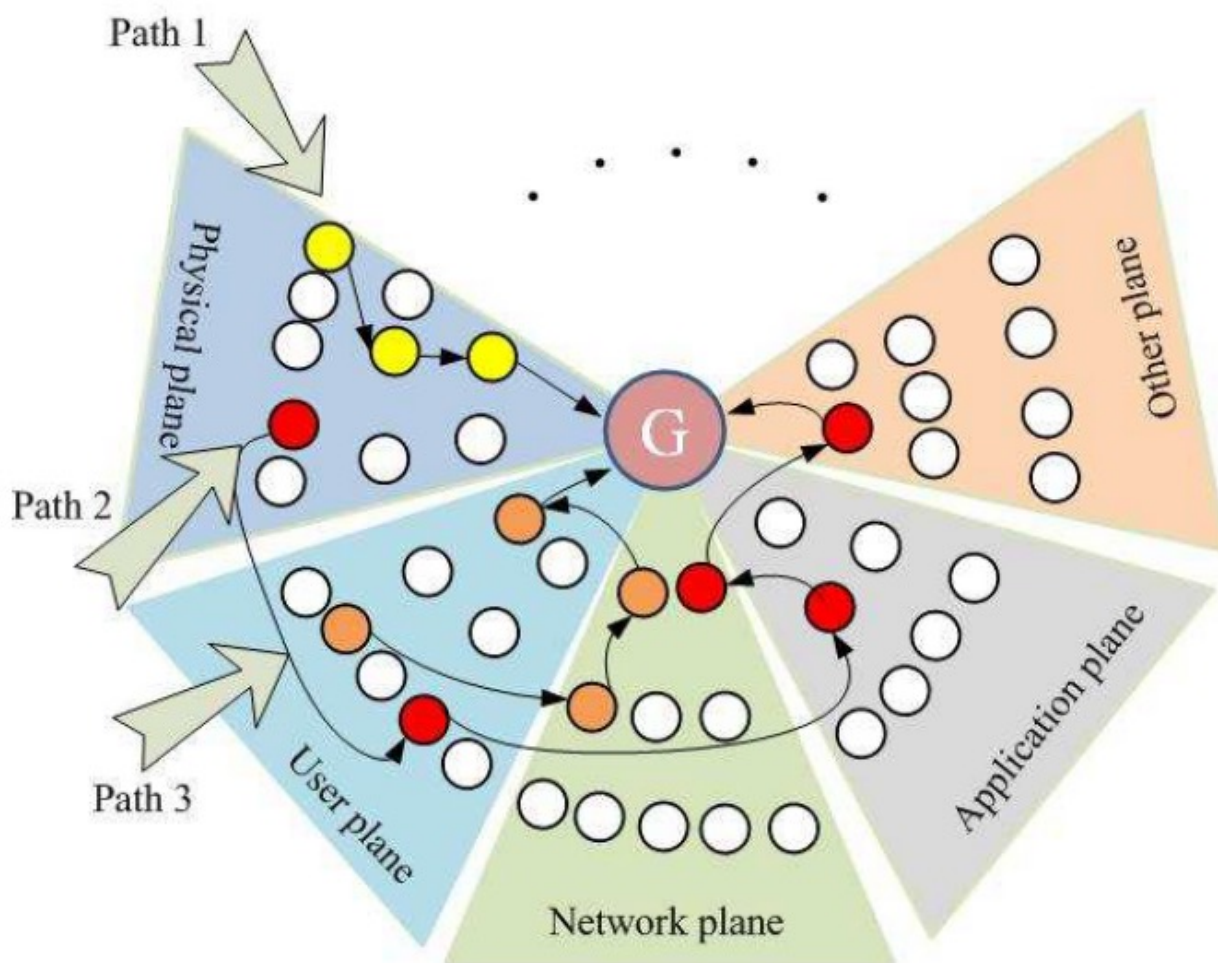
● 解决方案

❑ 基于大数据分析

● 检测原理

● 解决方案

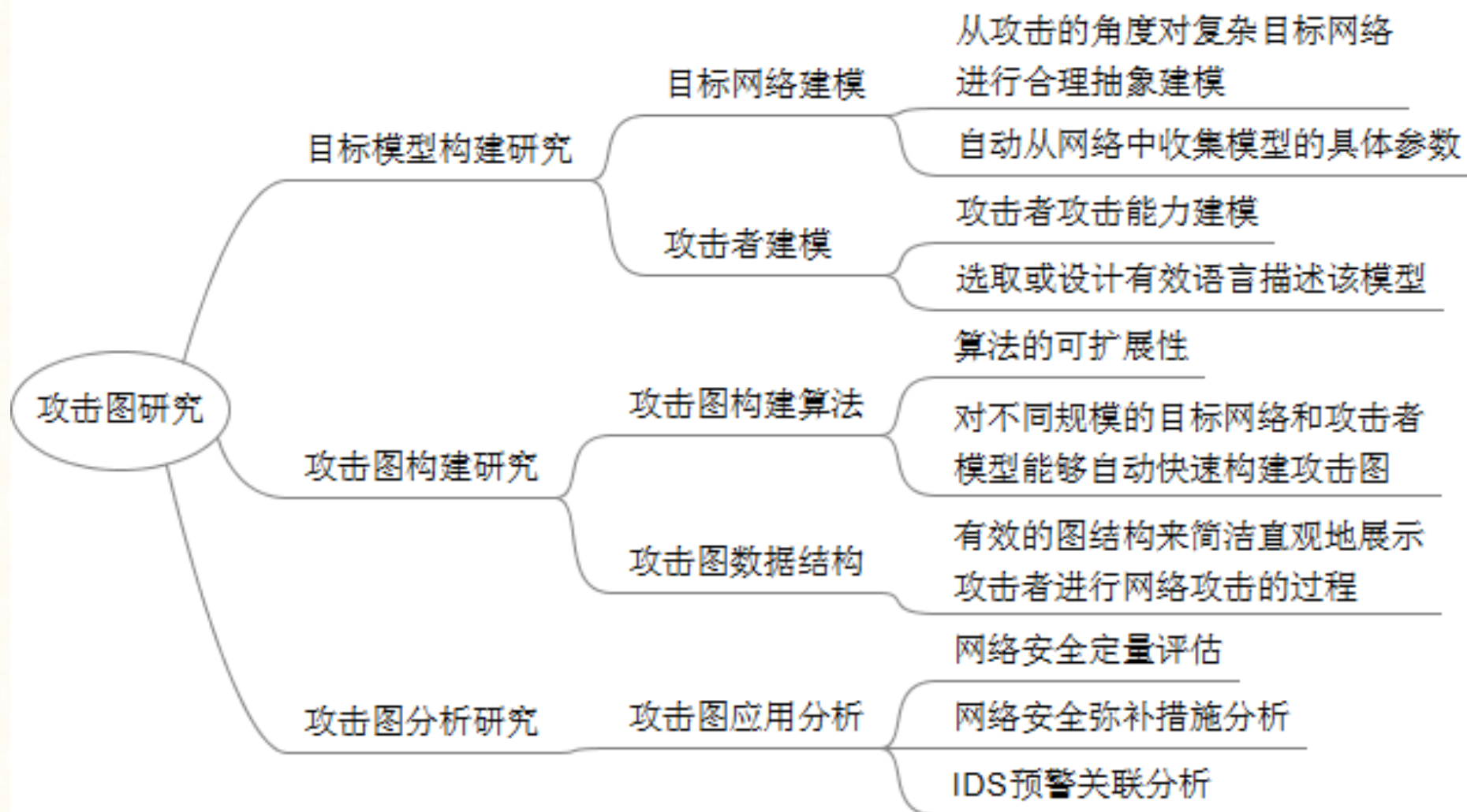
Content-Based APT Detection



APT检测方法——攻击图

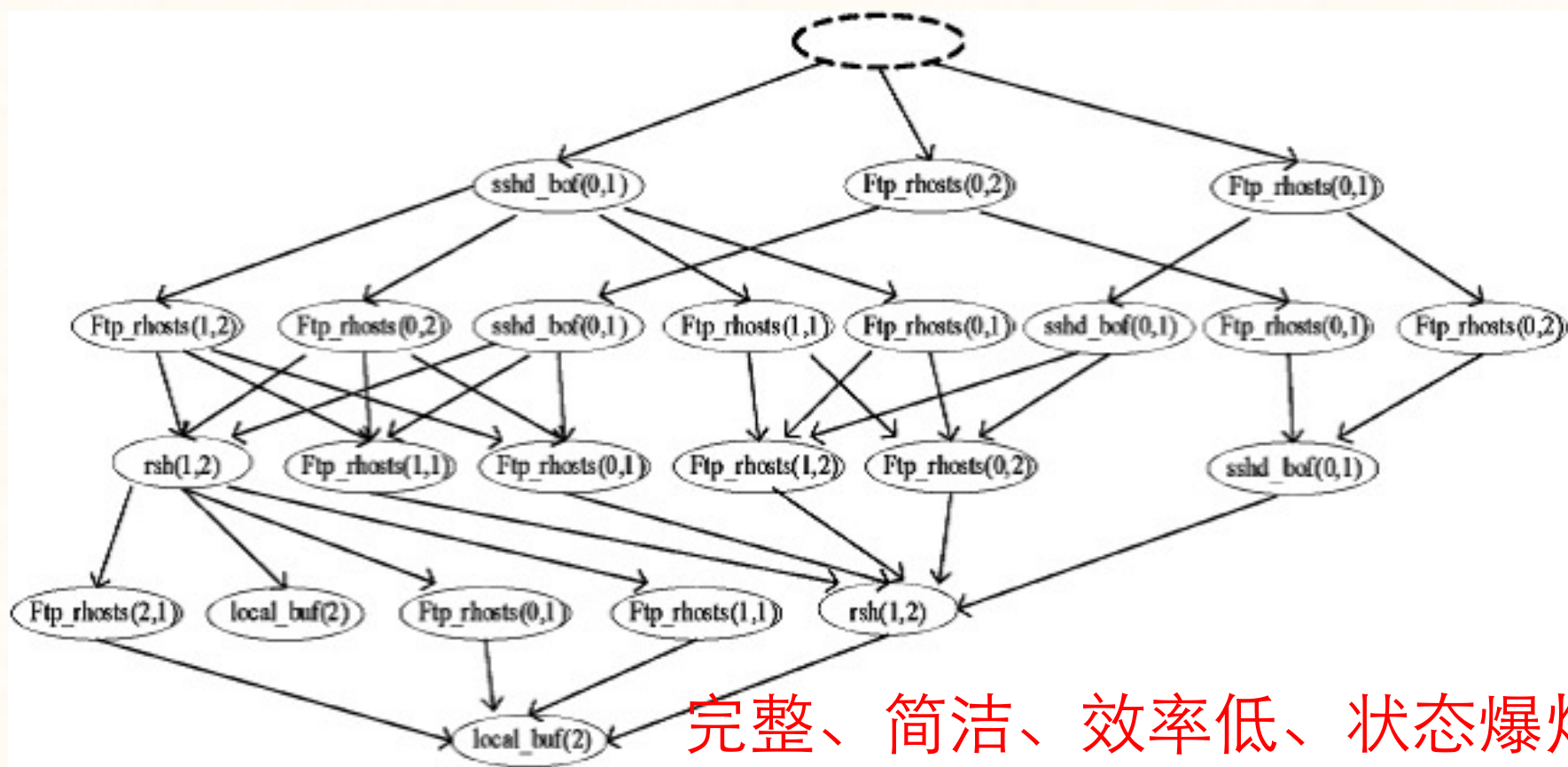
- 攻击图是**网络攻击建模技术**，它采用点和边的图形结构描述攻击场景。
- 在**目标网络建模**和**攻击者建模**的基础上，自动发现**系统脆弱性**间的关系，并根据攻击者和目标环境二者之间的相互作用关系计算产生攻击图。
- 展示**攻击路径**，并提供网络安全防护多方面的决策。
- 典型攻击图：**状态攻击图**、**属性攻击图**、**渗透依赖攻击图**...

APT检测方法——攻击图



状态攻击图

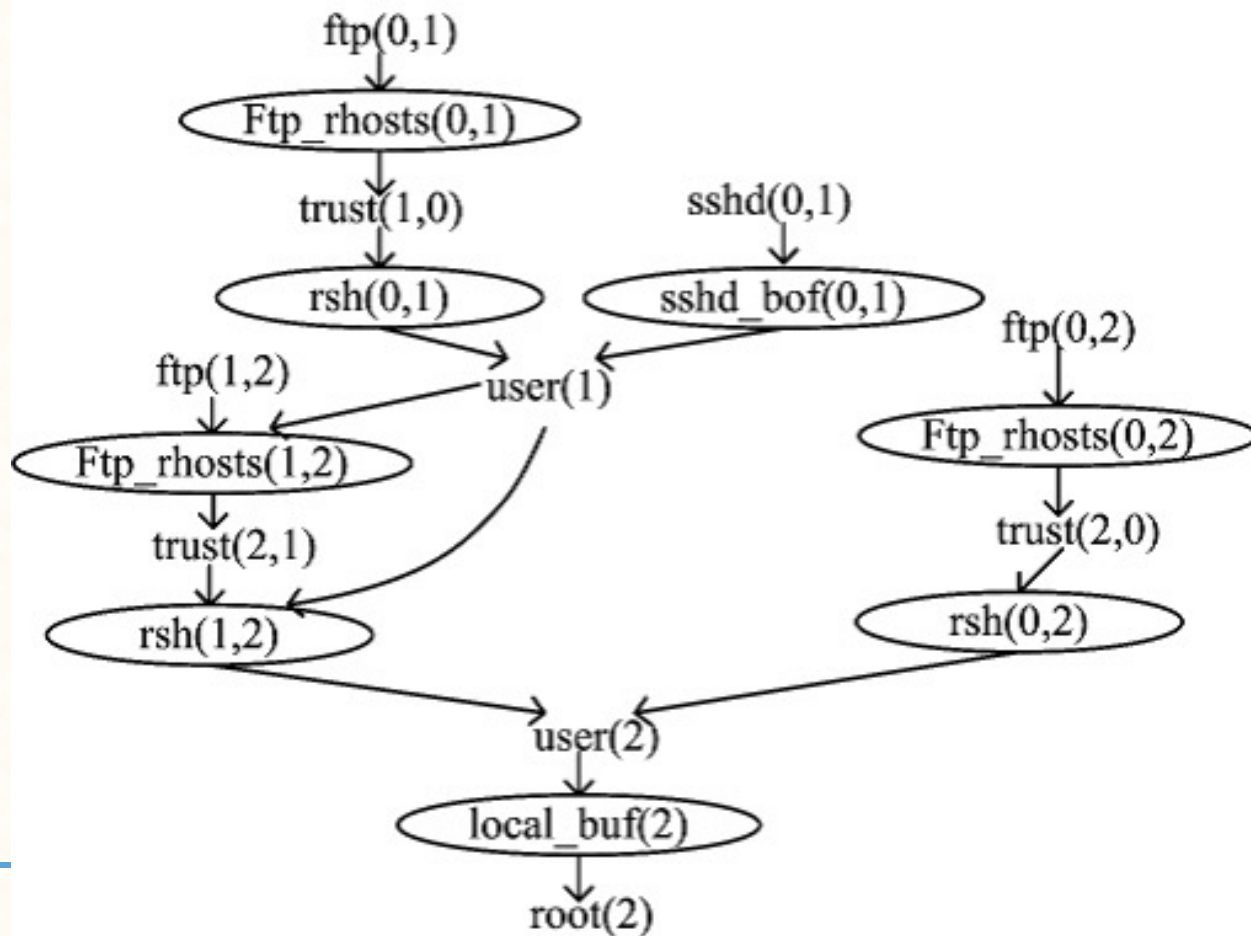
- 节点代表目标网络和攻击者的全局状态，节点内容通常包括主机名、用户权限、攻击的影响等。
- 每条弧代表原子攻击，它被执行后将会引起全局状态的变迁。



属性攻击图

椭圆：原子攻击节点；

文本：属性节点； 它表示这些原子攻击的每个前提或后果



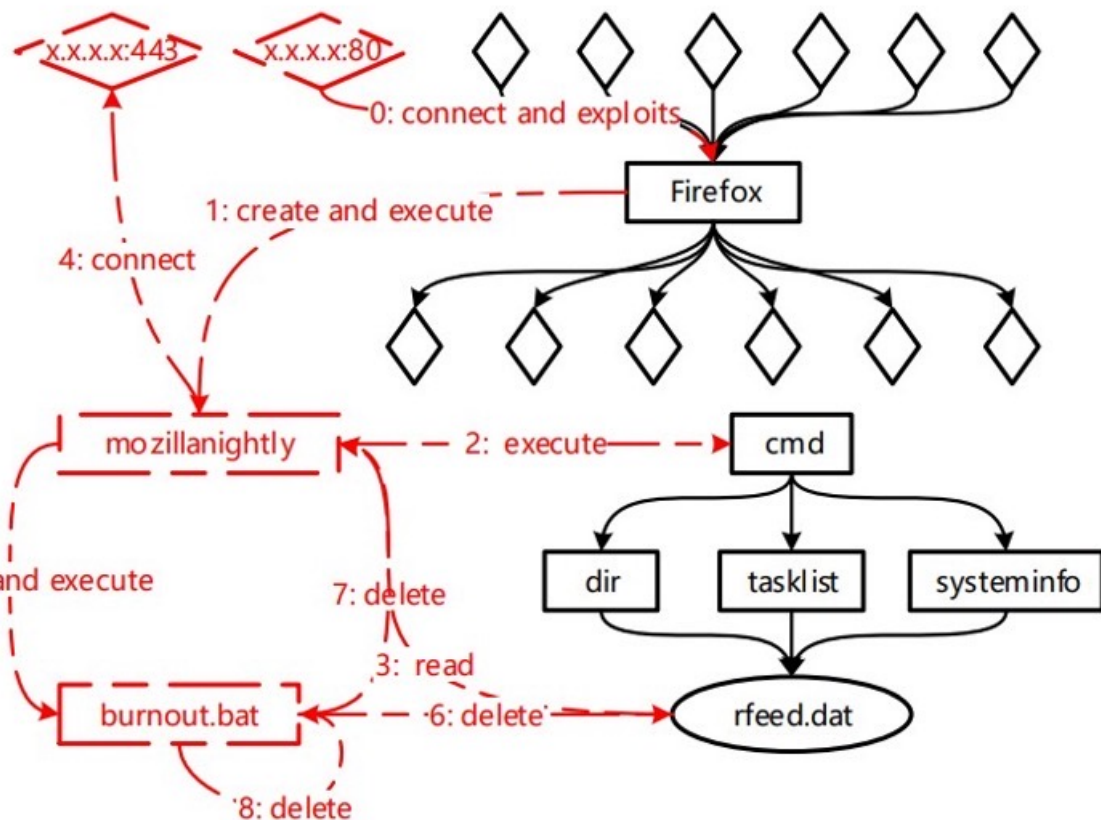
攻击溯源

- **APT攻击溯源的难点**

- 攻击持续时间长，攻击起点、过程、终点难以确定；
- 攻击片段化，攻击间关联弱化，难以有效还原整个攻击过程；
- 攻击数据分散，分治式的安全防护难以获取完整攻击数据来源，导致攻击离散化
- 数据量大，处理难度大

Provenance Graph

- 溯源图 (Provenance Graphs)
 - 表示主体和客体之间的控制流和信息流的关系的一种有向图
 - 主体和客体为节点，事件为边
- 结合溯源图的APT检测方法
 - 将原始日志数据转化为溯源图形式作为输入
- 优势
 - 非结构化的日志也能够提取溯源图
 - 包含时空信息，不容易被攻击者伪造躲避。
 - 保留了执行历史，便于检测长期且隐蔽的APT 攻击



SLEUTH: Real-time Attack Scenario Reconstruction from COTS Audit Data

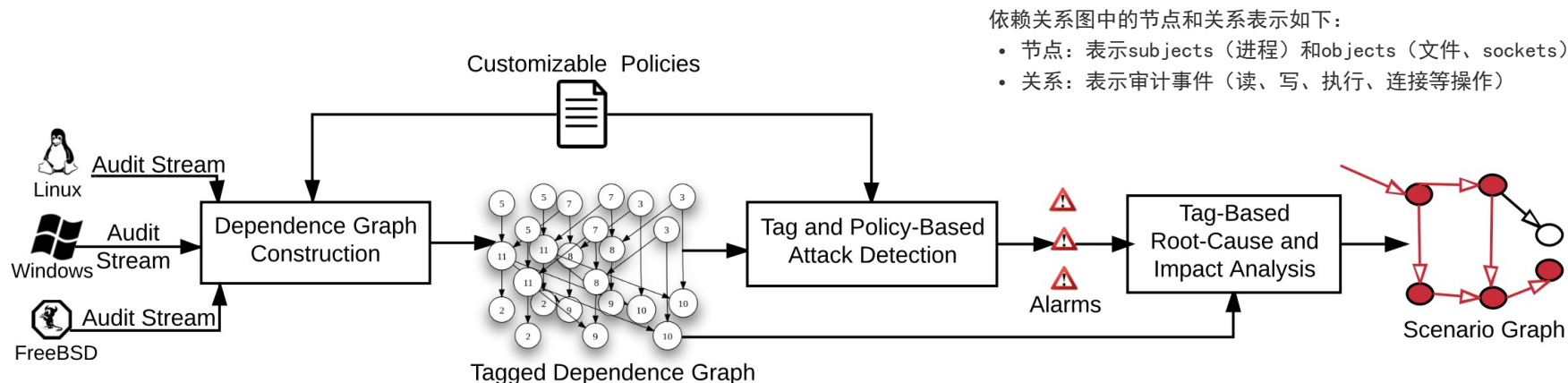


Fig. 1: SLEUTH System Overview

- SLEUTH的框架图如下图所示：
- (1) 输入的是Linux、Windows和FreeBSD平台的审计日志信息
- (2) 构建并标记依赖关系图，标签将提供重要的上下文信息，对应论文中良性可信、良性和未知三种类型
- (3) 实现基于标签和策略的攻击检测，并定制的策略，根据审计日志的秘密性分为公开、隐私、敏感和秘密，通过引入标签和策略实现对依赖关系图赋予不同的权重
- (4) 经过依赖图反复构建后，会到达警报计算阶段，通过定义规则来匹配更高的威胁攻击，生成对应的分数，基于标签的分析后会生成并还原场景图（Scenario Graph）

HOLMES: Real-time APT Detection through Correlation of Suspicious Information Flows

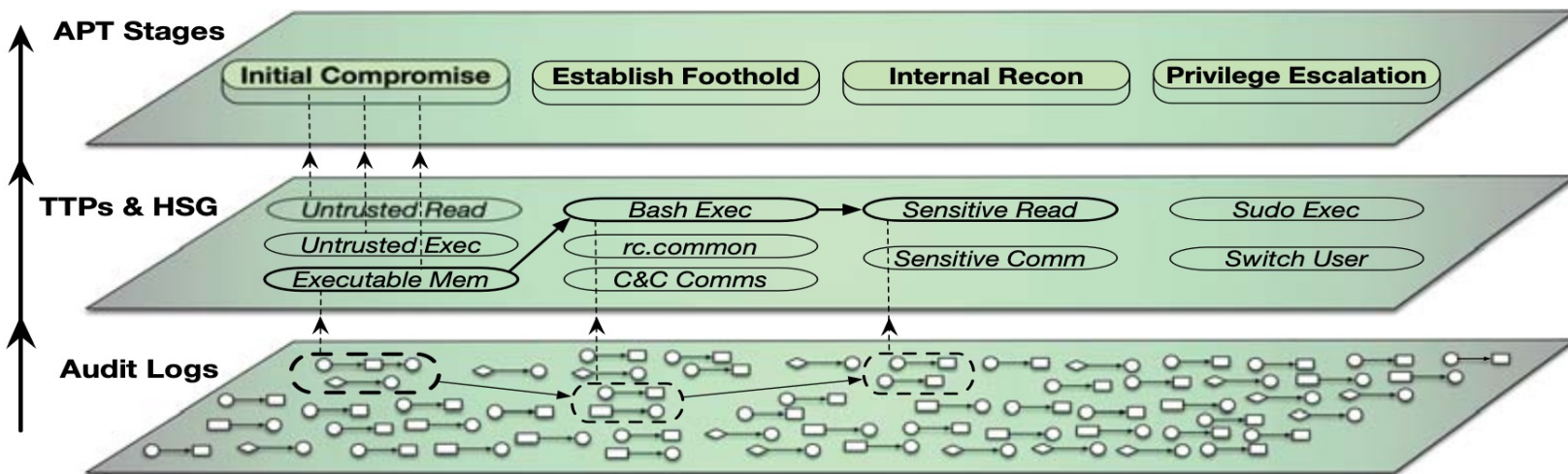


Fig. 3. HOLMES Approach: From Audit Records to High-Level APT Stages

- **Bridging the Semantic Gap.** To bridge the semantic gap between low-level system-call view and the high-level kill-chain view, we **build an intermediate layer** as shown in Fig. 3. The mapping to this intermediate layer is based on MITRE's ATT&CK framework [2], which describes close to 200 behavioral patterns defined as **Tactics, Techniques, and Procedures (TTPs)** observed in the wild.
- **Each TTP defines one possible way to realize a particular high-level capability.** For instance, the capability of persistence in a compromised Linux system can be achieved using 11 distinct TTPs, each of which represents a possible sequence of lower level actions in the ATT&CK framework, e.g., in- stallation of a rootkit, modification of boot scripts, and so on.
- For detecting correlations between attack steps, we **build a High-level Scenario Graph (HSG)** as an abstraction over the provenance graph.



- **Initial Compromise.** The attacker sends a malicious pay- load on the socket (S1) listening on port 80. As a result, Nginx makes some part of its memory region (M1) ex- ecutable. Next, the attacker gains control over the Nginx process by using a reflective self-loading exploit.
- **C&C Communications.** The compromised Nginx process makes a connection (S2) to the C&C server to receive commands from the attacker.
- **Privilege Escalation.** The attacker exploits an existing vulnerability to escalate the privilege of Nginx to root (U1).
- **Internal Reconnaissance.** Next, the attacker issues com- mands such as whoami (P5) and hostname (P6). These commands were used by the red team to simulate access to confidential/proprietary data. The attacker also reads usernames and password hashes (F2, F3, F4) and writes all this information to a temporary file.
- **Exfiltration.** Next, the attacker transfers the file containing the gathered information to her/his machine (S3).
- **Cleanup.** In the last step of the attack, the attacker removes the temporary file (F5) to clean up any attack remnants.

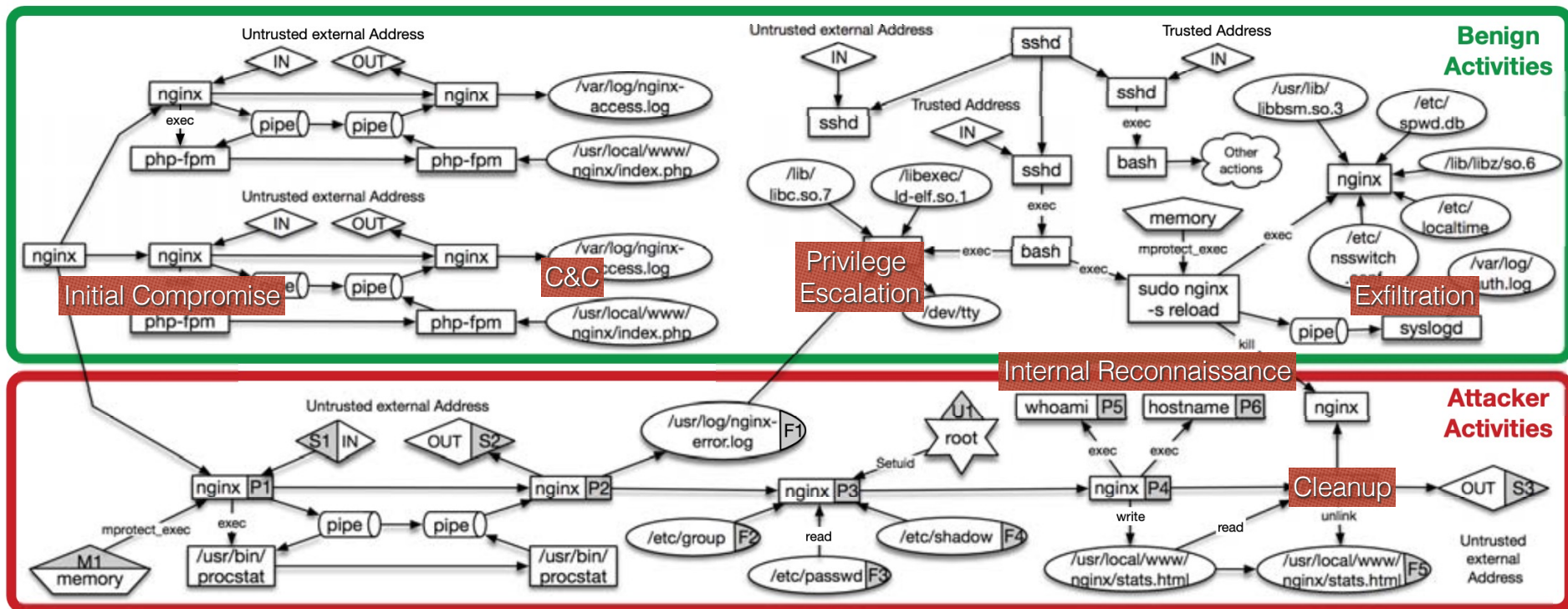


Fig. 2. Provenance Graph of the Running Example.

UNICORN: Runtime Provenance-Based Detector for Advanced Persistent Threats

- **UNICORN is a host-based intrusion detection system capable of simultaneously detecting intrusions on a collection of networked hosts.**

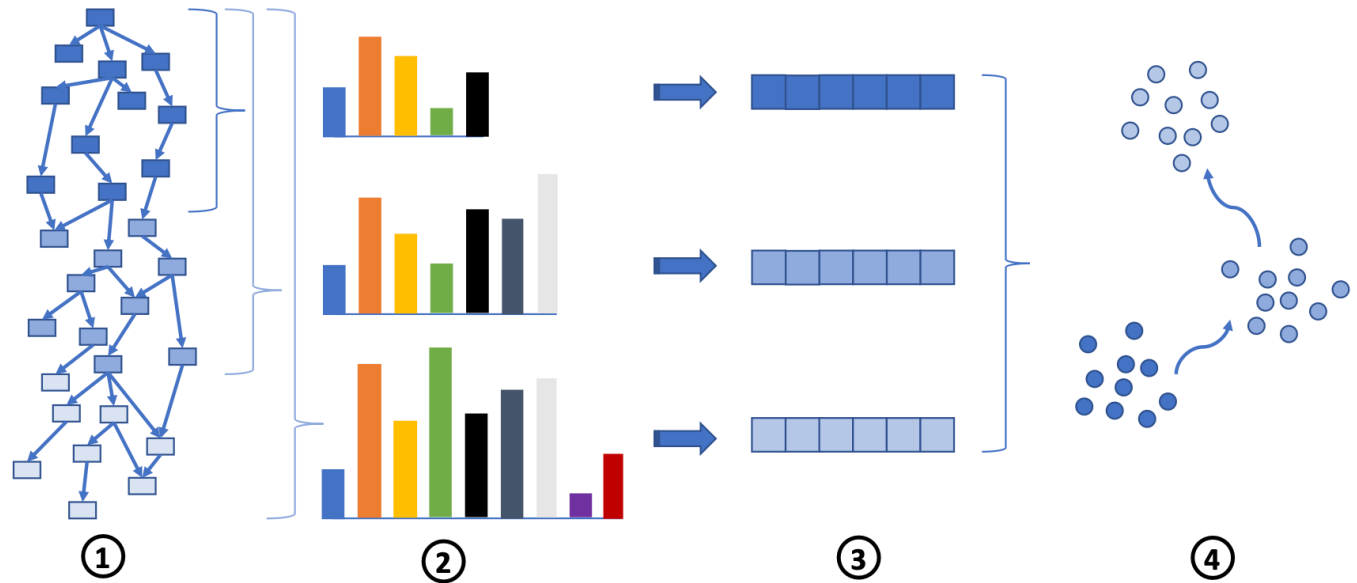
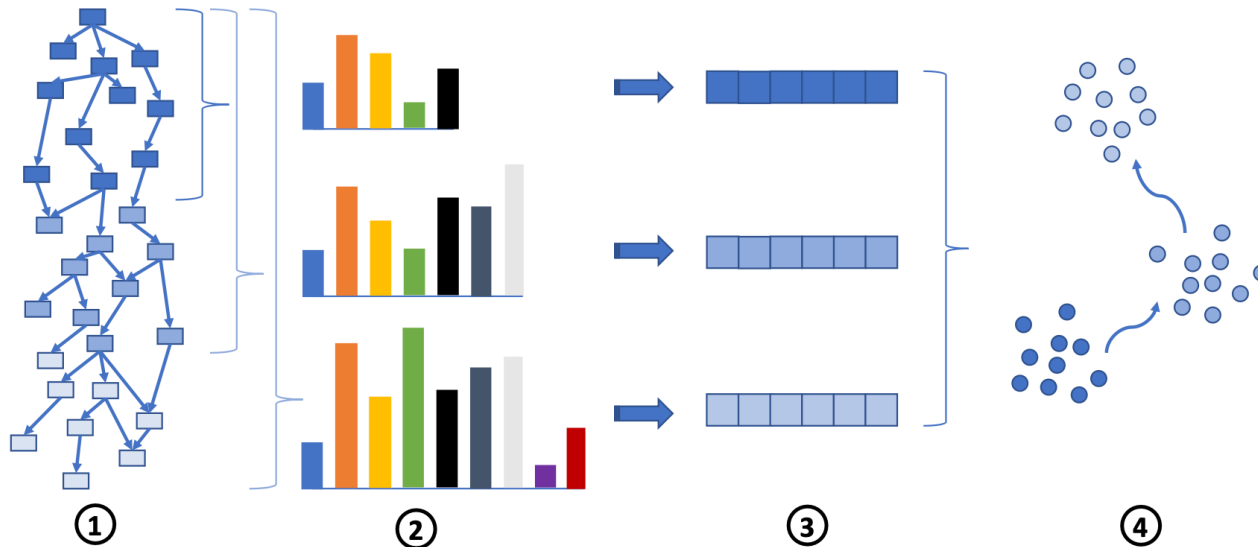


Fig. 1: UNICORN ① takes a streaming provenance graph, ② periodically summarizes graph features into histograms, and then ③ creates fixed-size graph sketches. The resulting clustering-based model ④ captures the dynamics of system execution. During deployment, graph sketches are created through the same steps (①, ② and ③) and then compared against the model in ④.

UNICORN: Runtime Provenance-Based Detector for Advanced Persistent Threats



- ① Takes as input a labeled, streaming provenance graph. Provenance systems construct a single, whole- system provenance DAG with a partial-order guarantee.
- ② Builds at runtime an in-memory histogram. Specifically, each element in the histogram describes a unique substructure of the graph, taking into consideration the heterogeneous label(s) attached to the vertices and edges within the substructure, as well as the temporal order of those edges.
- ③ Periodically, computes a fixed-size graph sketch. UNICORN employs a similarity- preserving hashing technique [132] to transform the histogram to a graph sketch [7].
- ④ Clusters sketches into a model. The model captures behavioral changes within a single execution by clustering system activities at various stages of its execution.

思考

- **APT到底能不能够阻止？**
 - 类比：个人安保
 - 个人：基本上没有安保措施
 - 明星：雇佣保镖
 - 总统：全方位的安全保护
- **APT攻击检测走向何方？**
 - 类比：刑事案件
 - 发生：实际上是罪犯经过长时间多手段的准备及实施，治安措施（如摄像头）有部分记录可查
 - 破案：总能够找到蛛丝马迹，顺藤摸瓜
 - 结论：缺少明确保护目标导致检测失败